



Cisco Networking Academy
Mind Wide Open

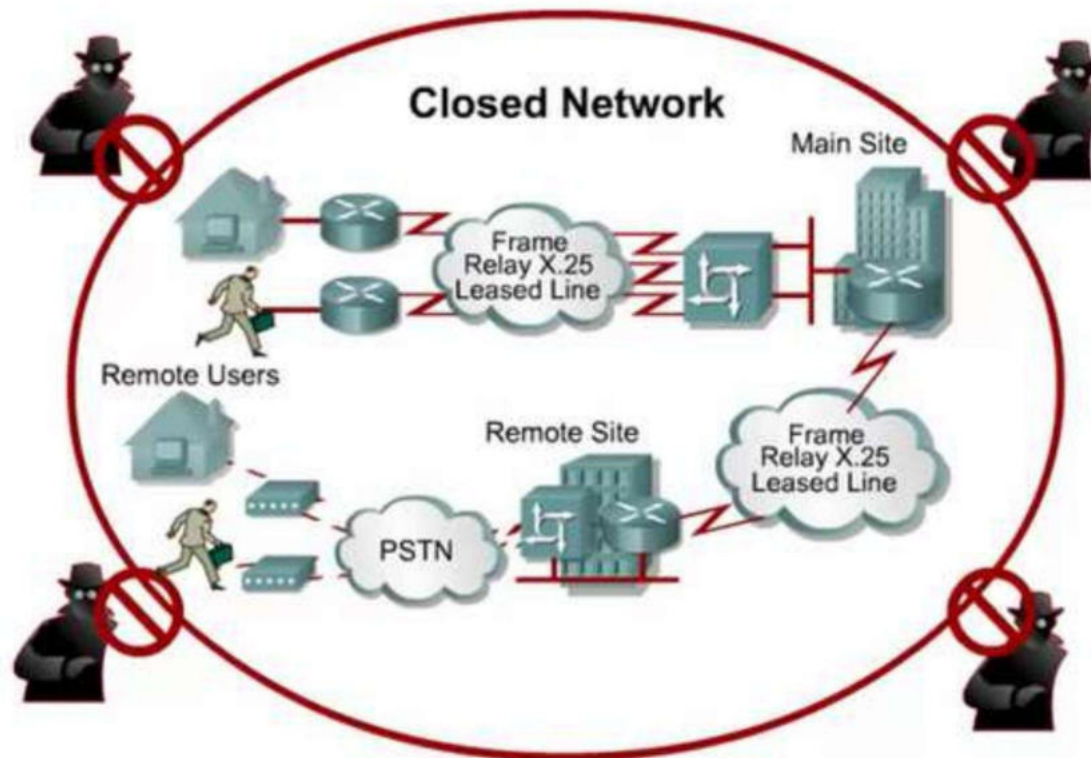
Chapter 1: Modern Network Security Threats

CCNA Security v2.0



Purpose of Security

- To protect assets!
 - Historically done through physical security and closed networks.

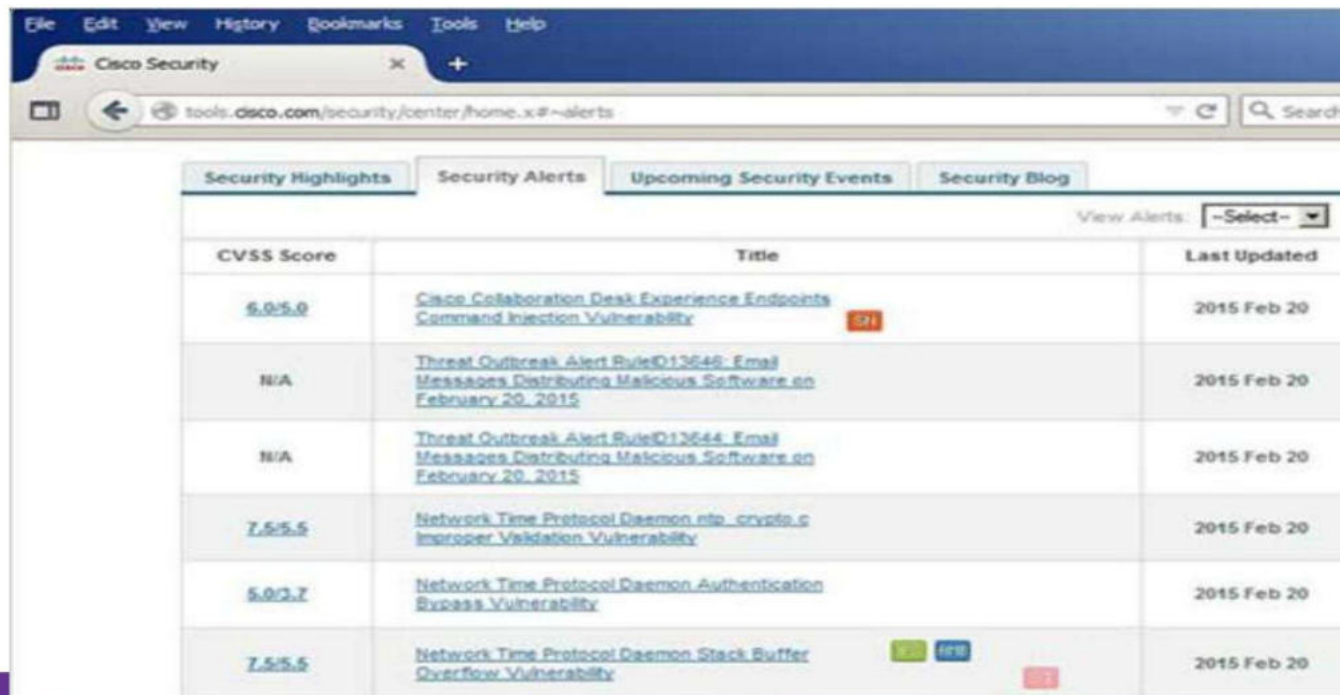


Drivers for Network Security

Common network security terms:

- Threat : potential for vulnerabilities to turn into network attack
- Vulnerability : weakness or flaw in the network.
- Mitigation : Action to reducing the severity of the vulnerability.
- Risk: it is potential of threat to exploit the vulnerabilities

Cisco Security Intelligence Operations



The screenshot shows the Cisco Security Intelligence Operations (SIO) web interface. The browser address bar displays 'tools.cisco.com/security/center/home.x?~alerts'. The interface includes tabs for 'Security Highlights', 'Security Alerts', 'Upcoming Security Events', and 'Security Blog'. A 'View Alerts' dropdown menu is set to '-Select-'. The main content area is a table with three columns: 'CVSS Score', 'Title', and 'Last Updated'. The table lists several security alerts, including 'Cisco Collaboration Desk Experience Endpoints Command Injection Vulnerability' (CVSS 6.0/5.0), 'Threat Outbreak Alert RuleID12646: Email Messages Distributing Malicious Software on February 20, 2015' (CVSS N/A), 'Threat Outbreak Alert RuleID12644: Email Messages Distributing Malicious Software on February 20, 2015' (CVSS N/A), 'Network Time Protocol Daemon ntp_crypt.c Improper Validation Vulnerability' (CVSS 7.5/5.5), 'Network Time Protocol Daemon Authentication Bypass Vulnerability' (CVSS 5.0/3.7), and 'Network Time Protocol Daemon Stack Buffer Overflow Vulnerability' (CVSS 7.5/5.5).

CVSS Score	Title	Last Updated
6.0/5.0	Cisco Collaboration Desk Experience Endpoints Command Injection Vulnerability	2015 Feb 20
N/A	Threat Outbreak Alert RuleID12646: Email Messages Distributing Malicious Software on February 20, 2015	2015 Feb 20
N/A	Threat Outbreak Alert RuleID12644: Email Messages Distributing Malicious Software on February 20, 2015	2015 Feb 20
7.5/5.5	Network Time Protocol Daemon ntp_crypt.c Improper Validation Vulnerability	2015 Feb 20
5.0/3.7	Network Time Protocol Daemon Authentication Bypass Vulnerability	2015 Feb 20
7.5/5.5	Network Time Protocol Daemon Stack Buffer Overflow Vulnerability	2015 Feb 20

Computer Security Terminology

» Vulnerability

- A weakness which can be exploited by an attacker in its benefit, for example
 - Physical environment, software bugs
 - Protocol / system design flaws
 - Weak passwords

» Threat

- Event or circumstance which causes damage to systems, could exploit a vulnerability, for example
 - Physical (fire, water, earthquake)
 - Malicious codes (virus, trojan, malware)
 - Phishing, social engineering

Computer Security Terminology

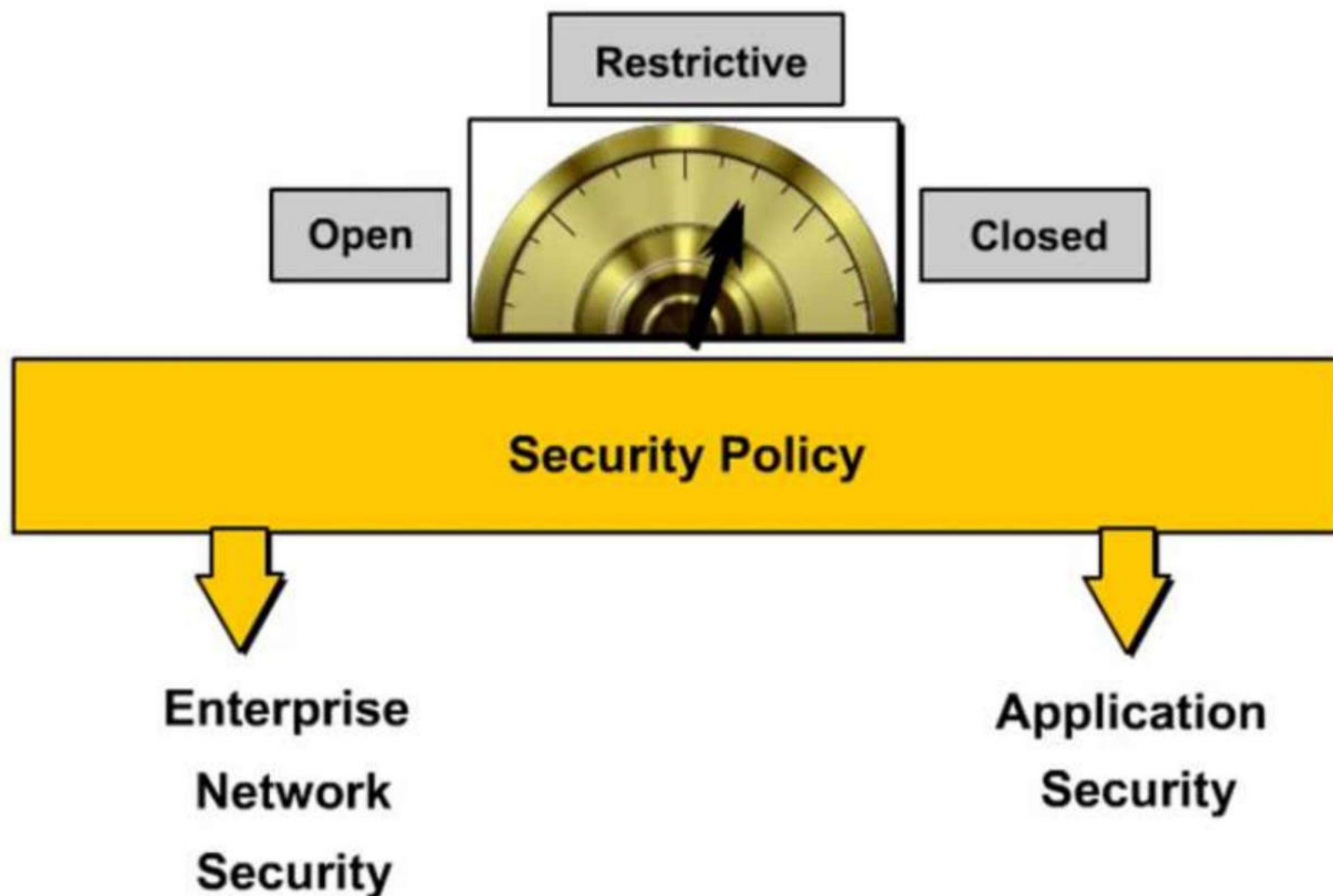
» Exploit

- Mechanism or tool used to take advantage of a vulnerability, in order to compromise the security or functionality of a system
 - Sequence of commands
 - Piece of software or chunk of data

» Risk

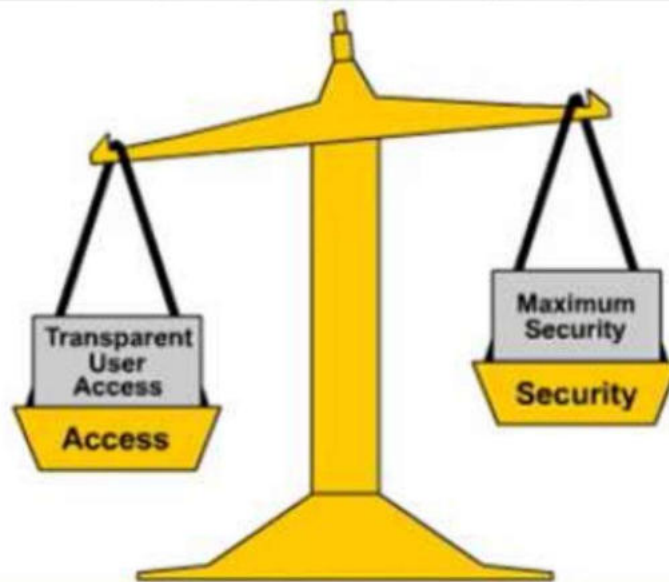
- The probability of a threat or event to happen
 - Security Risk cannot be completely mitigated
 - Remaining risk is called residual risk or accepted risk

Network Security Models



Open Security Model

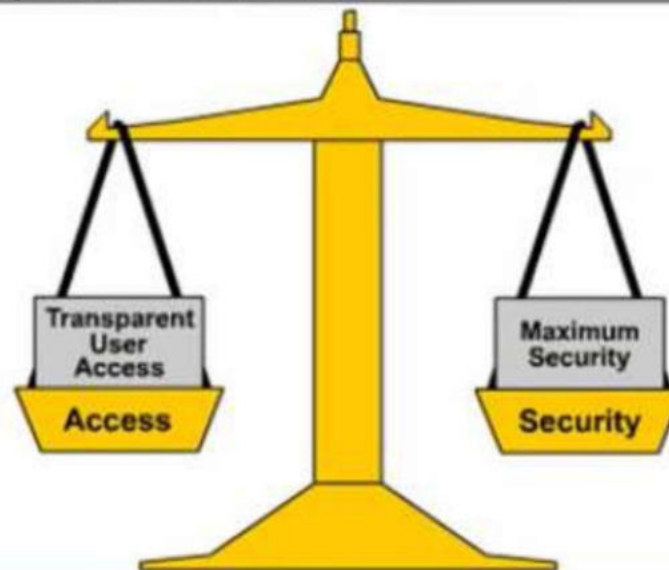
Permit everything that is not explicitly denied



- Easy to configure and administer
- Easy for network users
- Security Costs: Least expensive

Restrictive Security Model

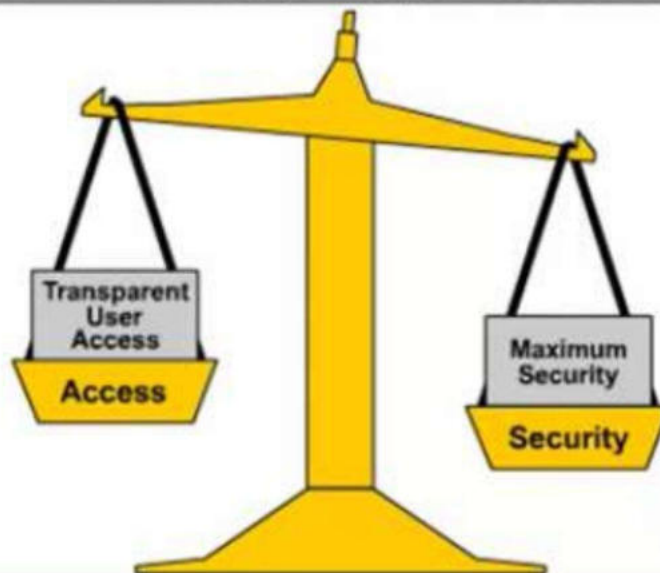
Combination of specific permissions and specific restrictions



- More difficult to configure and administer
- More difficult network users
- Security Cost: More expensive

Closed Security Model

That which is not explicitly permitted is denied



- Most difficult to configure and administer
- Most difficult network users
- Security Cost: Most expensive



Vectors of Network Attacks

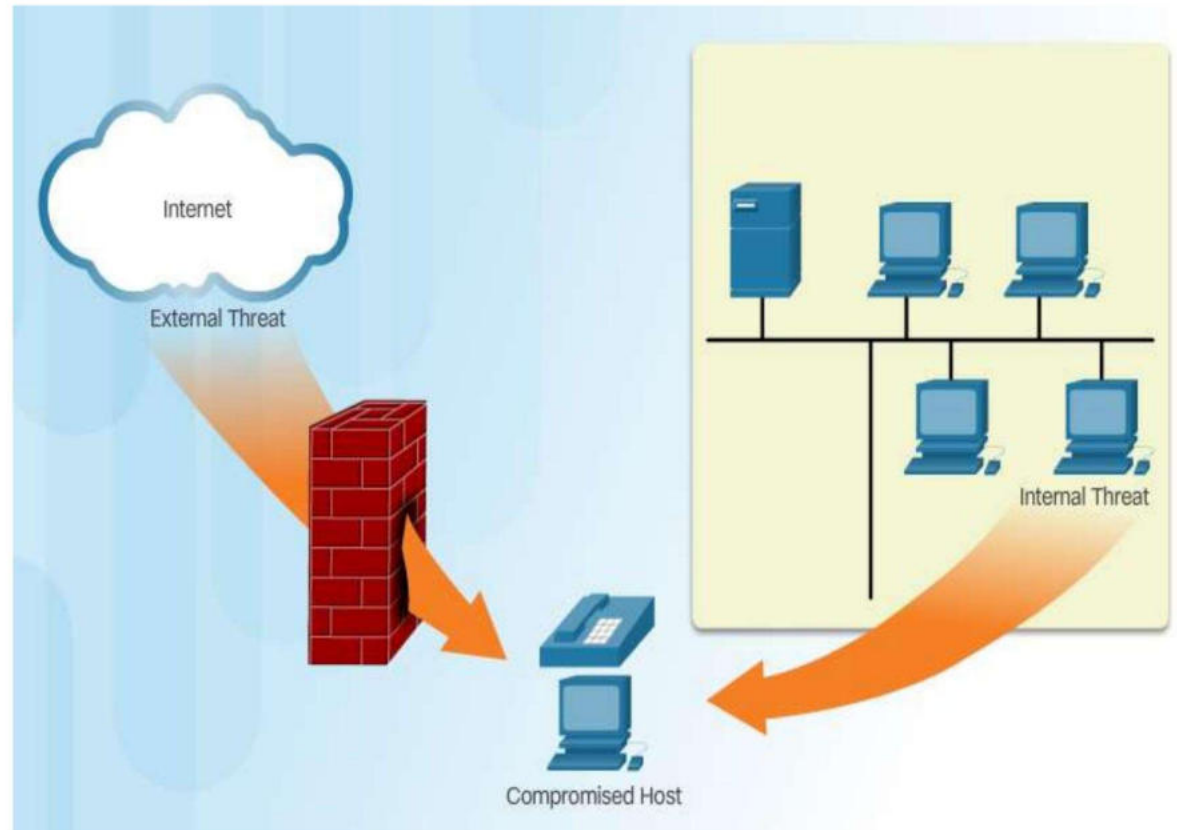
An attack vector is a path or other means by which an attacker can gain access to a server

An attack vector is defined as the technique by means of which unauthorized access can be gained to a device or a network by hackers for nefarious purposes.

Many attack vectors originate from outside the corporate network and from inside network

Internal threat can cause great damage than external threat because the internal user have a direct access to the network

Network security professionals must implement tools and apply techniques for mitigating both external and internal threats



Data Loss

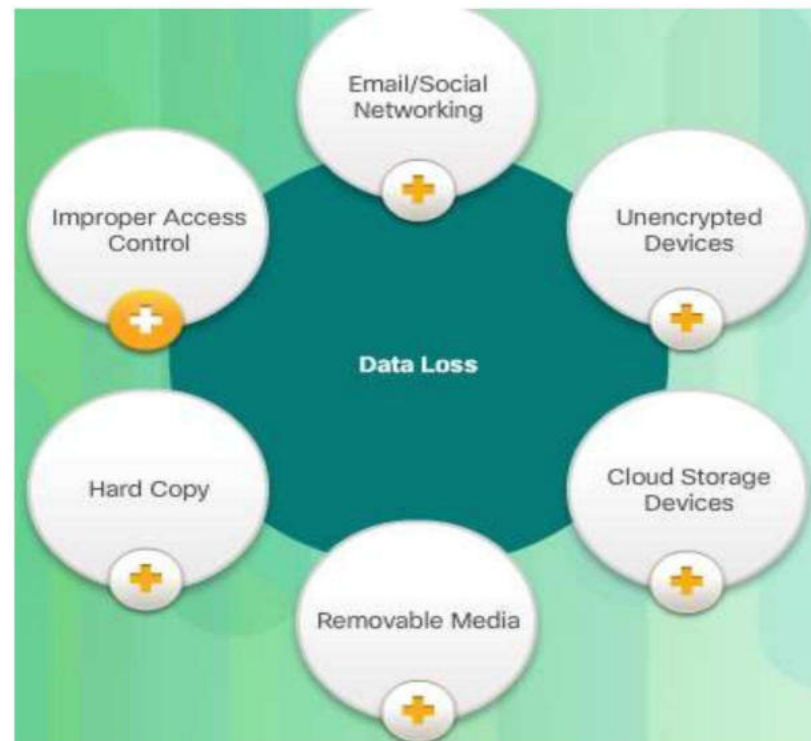
Data is likely to be an organization's most valuable asset. Data like research and development data, sales data, financial data, legal data...etc

Network security professionals must protect the organization's data.

Data loss or data exfiltration is when data is intentionally or unintentionally lost, stolen, or leaked to the outside world. The Various Data Loss Prevention (DLP) controls must be implemented.

Vectors of data loss:

- Email/Webmail (instance message)
- Unencrypted Devices
(data is stored without encryption algorithm on the devices)
- Cloud Storage Devices
(access is compromised)
- Removable Media
- Hard Copy
- Improper Access Control
(stolen/weakness password)



Topic 1.1.2: Network Topology Overview



Data Center Networks

Data center networks are typically housed in an off-site facility to store sensitive or proprietary data. These sites are interconnected to corporate sites using VPN technology with ASA devices and integrated data center switches.

Today's data centers store vast quantities of sensitive, business-critical information; therefore, **physical security is critical to its operation.**

Data center physical security can be divided into two areas:

Outside perimeter security:

- On-premise security officers
- Fences and gates
- Continuous video surveillance
- Security breach alarms

Physical security not only protects access to the premise but also protects people and equipment.

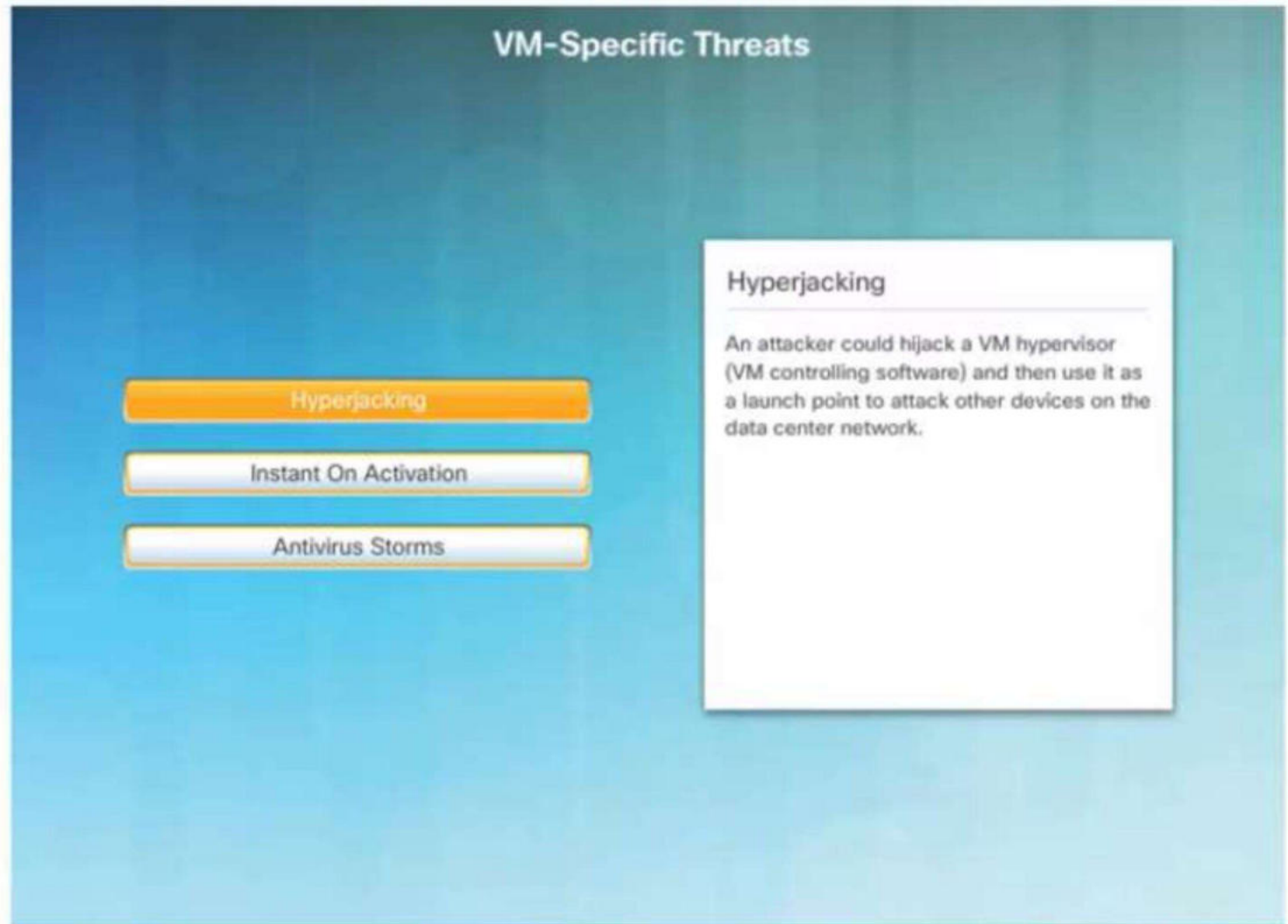
Inside perimeter security:

- Electronic motion detectors
- Security traps
- Continuous video surveillance
- Biometric access and exit sensors

Cloud and Virtual Networks بدون الصورة

VM-specific threats:

- Hyperjacking
- Instant On activation
- Antivirus storm



Cloud and Virtual Networks بدون الصورة

Components of a secure data center:

- Secure segmentation
- Threat defense
- Visibility



Cloud and Virtual Networks مهم جداً

Virtualization is the foundation of Cloud computing. Without it, Cloud computing, as it is most-widely implemented, would not be possible.

Cloud computing separates the application from the hardware. Virtualization separates the OS from the hardware.

Cloud computing allows organizations to use services such as data storage or Cloud-based applications, to extend their capacity or capabilities without adding infrastructure.

The actual Cloud network consists of physical and virtual servers which are commonly housed in data centers.

The Evolving Network Border

In the past, employees and data resources remained within a predefined perimeter that was protected by firewall BUT today we have a BYOD so Cisco developed the Borderless Network.

Critical **MDM** (**mobile device management**) functions for BYOD network:

- Data encryption
- PIN enforcement (PIN lock)
- Data wipe (**data** clearing remotely by MDM)
- Data loss prevention
- Jailbreak/root detection

Components of a secure data center:

- Secure segmentation
- Threat defense
- Visibility

VM-specific threats:

- Hyperjacking
- Instant On activation
- Antivirus storm

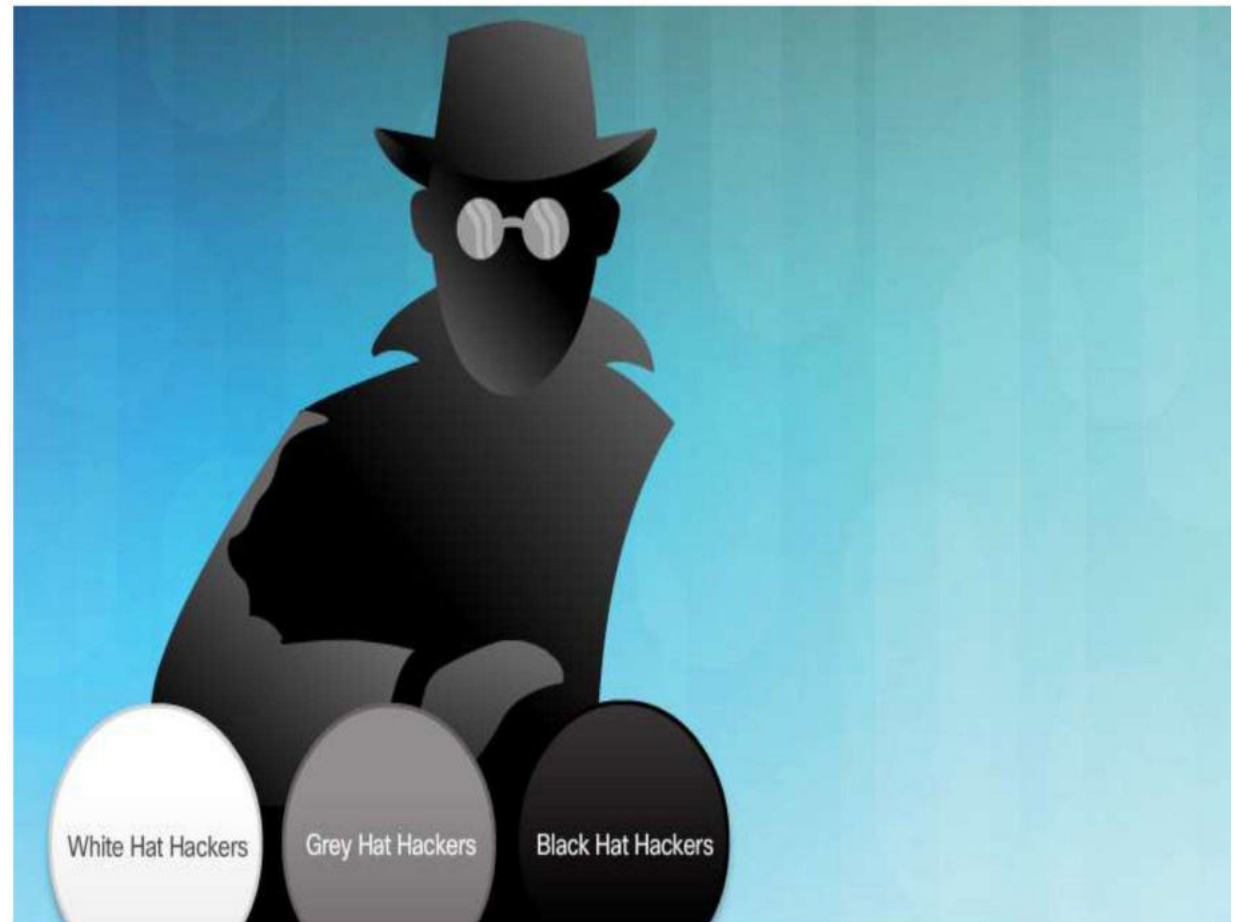
MDM features secure, monitor, and manage mobile devices, including corporate-owned devices and employee-owned devices.

The Hacker & The Evolution of Hackers

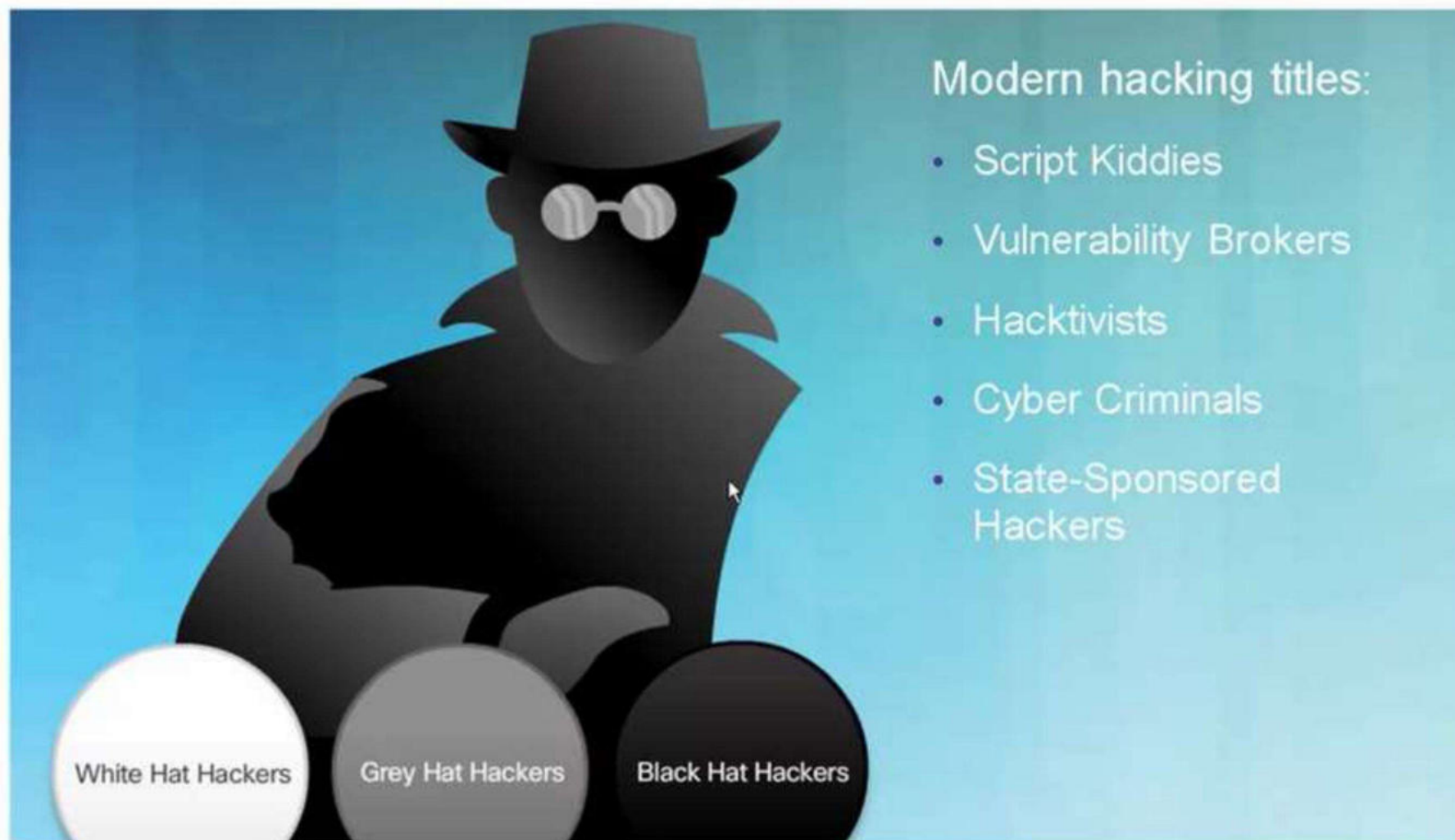


The term “hacker” has a variety of meanings:

- A clever programmer .
- A network professional that uses sophisticated programming skills to ensure that networks are not vulnerable to attack.
- A person who tries to gain unauthorized access to devices on the Internet.
- Individuals who run programs to prevent or slow network access to a large number of users, or corrupt or wipe out data on servers.



The Hacker & The Evolution of Hackers



The Hacker & The Evolution of Hackers(cont.)

- Hacking started in the 1960s with phone freaking, or phreaking, which refers to using various audio frequencies to manipulate phone systems.
- In the mid-1980s, computer dial-up modems were used to connect computers to networks. Hackers wrote “war dialing” programs which dialed each telephone number in a given area in search of computers then password-cracking programs were used to gain access.

Modern hacking titles:

- **Script Kiddies:** He is an unskilled individual who uses **scripts** or programs developed by others to attack computer systems and networks and deface websites.
- **Vulnerability Brokers**
- **Hactivists:** a person who breaks into a computer system in order to pursue a political or social aim. One of **hactivist groups is Wikileaks . It is a hack for attention.**
- **Cyber Criminals :** They are black hat hackers with the motive to make money using any means necessary. They operate in an underground economy where they buy, sell, and trade attack toolkits, zero day exploit code, botnet services, banking Trojans, keyloggers, and much more.
- **State-Sponsored Hackers :** They are the newest type of hacker. These are government-funded and guided attackers, ordered to launch operations that vary from cyber espionage to intellectual property theft. Many countries sponsor these hackers but very few will publically admit they exist.

Modern Hacking Titles

مهم جداً



Evolution of Security Tools

Ethical hacking involves many different types of tools to test and keep the network and its data secure.

To validate the security of a network and its systems, many network penetration testing tools have been developed. However, many of these tools can also be used by black hat hackers for exploitation.

Penetration testing tools:

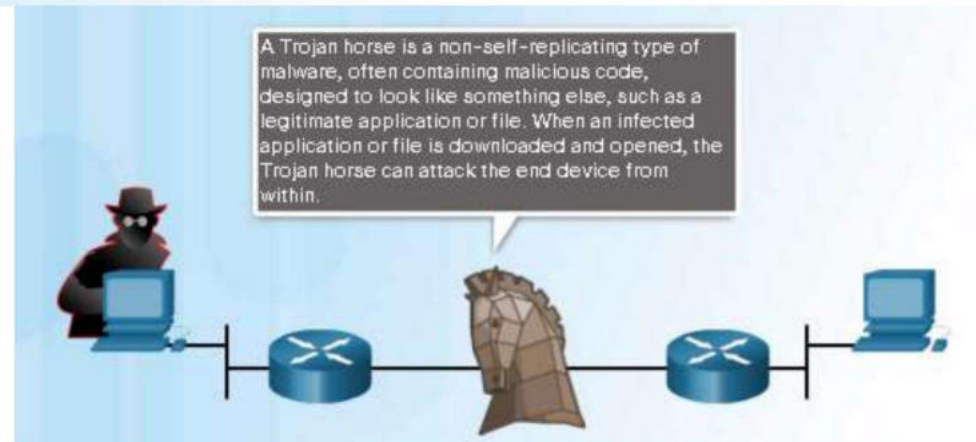
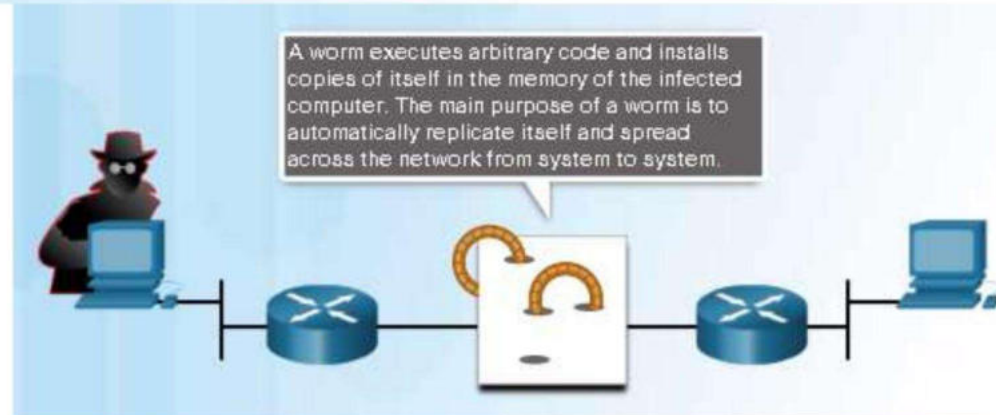
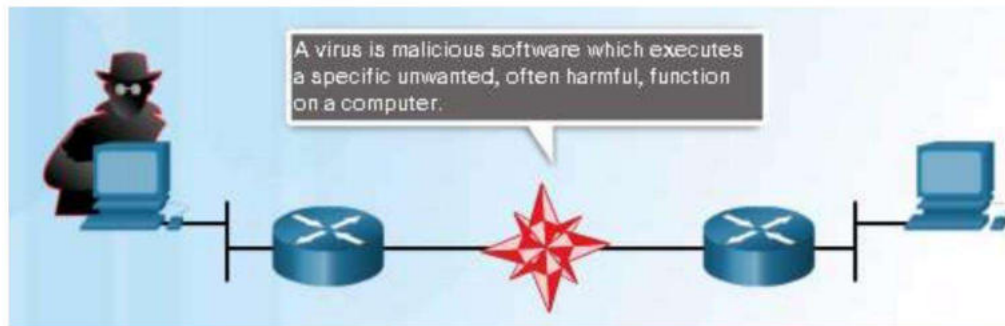
- Password crackers
- Wireless hacking
- Network scanning and hacking
- Packet crafting (the art of creating a packet according to various requirements to carry out attacks and to exploit vulnerabilities in a network. Like Netcat)
- Packet sniffers
- Rootkit detectors (Directory/file integrity checker)
- Fuzzers to search vulnerabilities (are tools used by hacker attempting to discover a computer system's security)
- Forensic (to sniff out any trace of evidence existing in a particular computer system)
- Debuggers (debugging tool is a computer program that is used to test and debug other programs (the "target" program)
- Hacking operating systems (kali Linux)
- Encryption
- Vulnerability exploitation
- Vulnerability Scanners

Categories of Attack Tools

Network hacking attacks:

- **Eavesdropping** : This is when a hacker captures and “listens” to network traffic. This attack is also referred to as sniffing or snooping.
- Data modification
- IP address spoofing
- Password-based
- Denial-of-service
- Man-in-the-middle
- **Compromised-key** (If a hacker obtains a secret key, that key is referred to as a compromised key. A compromised key can be used to gain access to a secured communication without the sender or receiver being aware of the attack.)
- **Sniffer** : A sniffer is an application or device that can read, monitor, and capture network data exchanges and read network packets.

Various Types of Malware



Viruses

A virus is malicious code that is attached to executable files which are often legitimate programs.

It require end user activation and can lay dormant for an extended period and then activate at a specific time or date.



Trojan Horse Definition / Classification

Trojan horse is malware that carries out malicious operations under the guise of a desired function. A Trojan horse comes with malicious code hidden inside of it.

Unlike a computer virus, a Trojan horse is not able to replicate itself, nor can it propagate without an end user's assistance.

Trojan horses are usually classified according to the damage that they cause or the manner in which they breach a system,

Classifications:

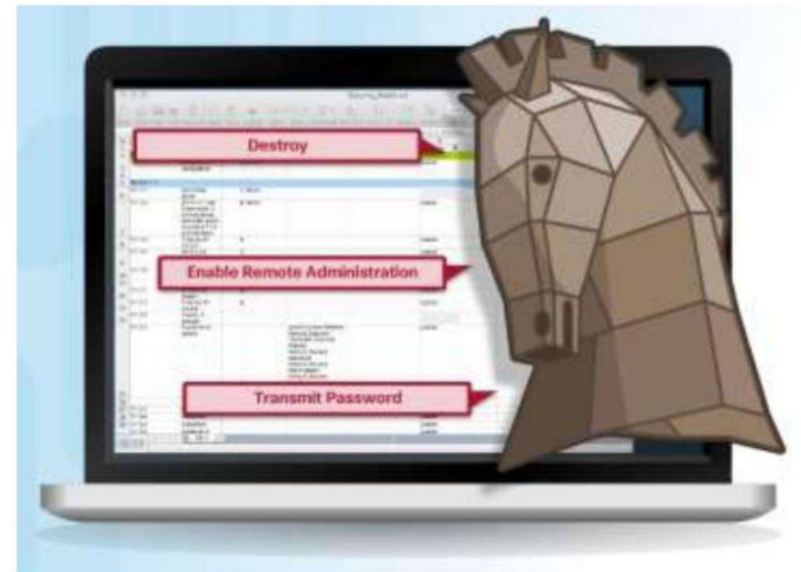
- **Security software disabler :**

Stops antivirus programs or firewalls from functioning.

- **Remote-access**

- **Data-sending:** providing with sensitive data

- **Destructive:** This corrupts or deletes files.



Proxy : use the victim's computer as the source device to launch attacks and perform other illegal activities.

FTP : enables unauthorized file transfer services on end devices.

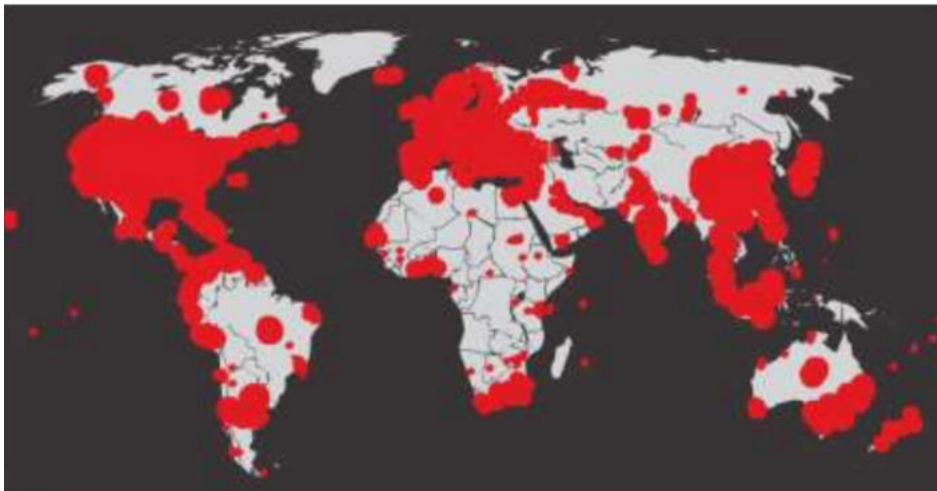
DoS : slows or halts network activity.

Worms

Worms replicate themselves by independently exploiting vulnerabilities in networks. Worms usually slow down networks. Whereas a virus requires a host program to run, worms can run by themselves.



Initial Code Red Worm Infection



Code Red Worm Infection 19 Hours Later

Worm Components مهم جداً

Most worm attacks consist of three components:

- Enabling vulnerability

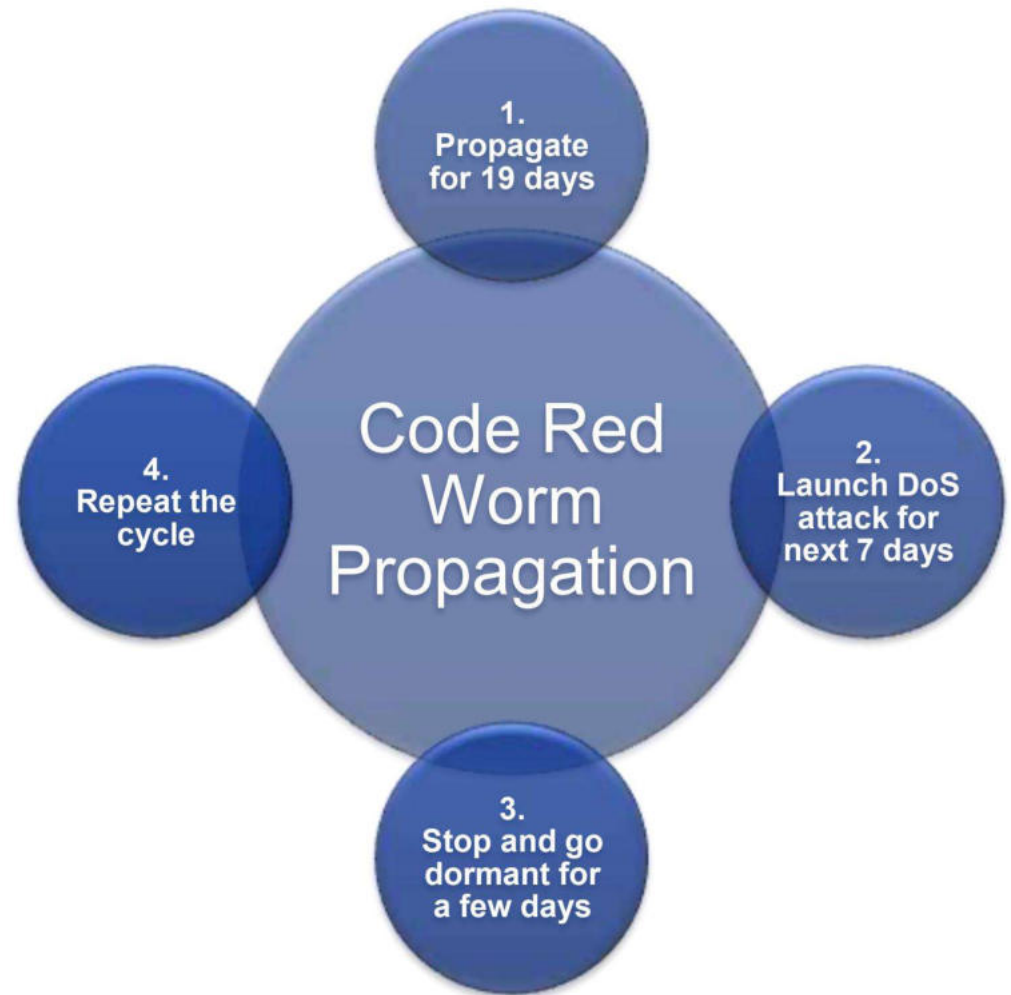
A worm installs itself using an exploit mechanism, such as an email attachment, an executable file, or a Trojan horse, on a vulnerable system.

- Propagation mechanism

After gaining access to a device, the worm replicates itself and locates new targets.

- Payload

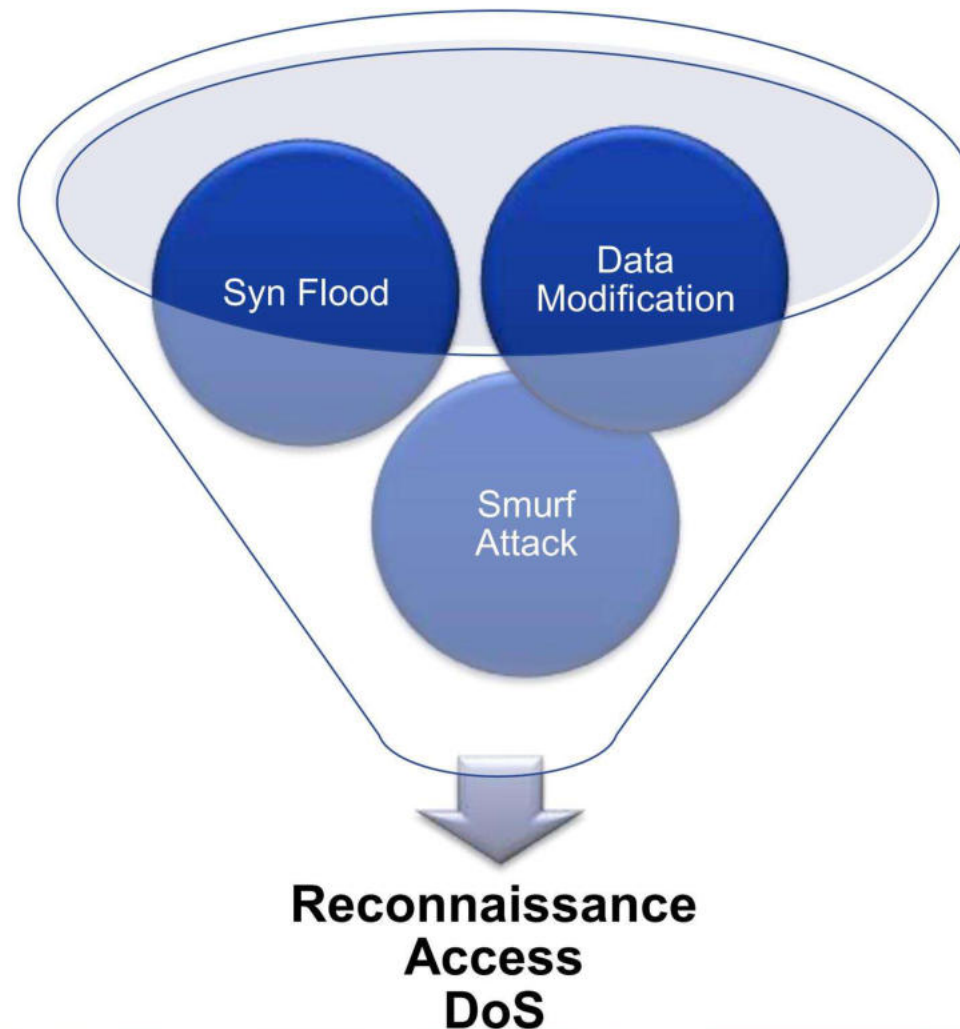
Any malicious code that results in some action is a payload. Most often this is used to create a backdoor to the infected host or create a DoS attack.



Types of Network Attacks مهم

Malware is a means to get a payload delivered. When it is delivered and installed, the payload can be used to cause a variety of network related attacks.

To mitigate attacks, it is useful to first categorize the various types of attacks.



Reconnaissance Attacks

Reconnaissance is known as information gathering. Hackers use reconnaissance (or recon) attacks to do unauthorized discovery and mapping of systems, services, or vulnerabilities.

These are some of the techniques used by malicious hackers conducting reconnaissance attacks:

- Initial query of a target
- Ping sweep of the target network
- Port scan of active IP addresses
- Vulnerability scanners
- Exploitation tools



Access Attacks مهم

Access attacks exploit known vulnerabilities in authentication services, FTP services, and web services to gain entry to web accounts, confidential databases, and other sensitive information.

A few reasons why hackers use access attacks:

- To retrieve data
- To gain access
- To escalate access privileges

A few types of access attacks include:

- Password
- Trust exploitation
- Port redirection
- Man-in-the-middle
- Buffer overflow
- IP, MAC, DHCP spoofing

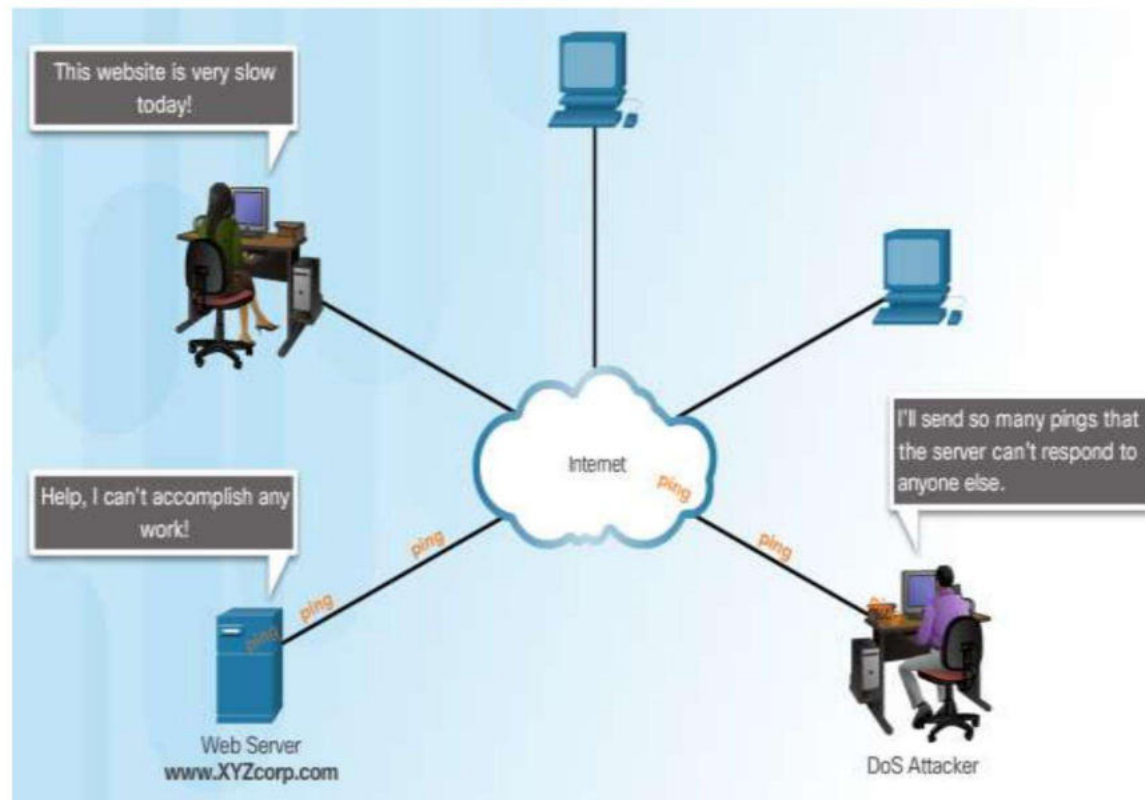
Denial of Service Attacks مهم

Two major sources of DOS attacks:

- Maliciously formatted packet
this causes the receiving device to crash or run very slowly.
- Overwhelming quantity of traffic:
this is when a network, host or application is unable to handle enormous quantity of data .Causing crash system or slow performance.

Types of DOS:

ping of death
smurf attack
TCP SYN flood



DDoS Attacks

A Denial of Service (**DoS**) attack is different from a **DDoS** attack. The **DoS** attack typically uses one computer and one Internet connection to flood a targeted system or resource. The **DDoS** attack uses multiple computers and Internet connections to flood the targeted resource.

a DDoS attack could proceed as follows:

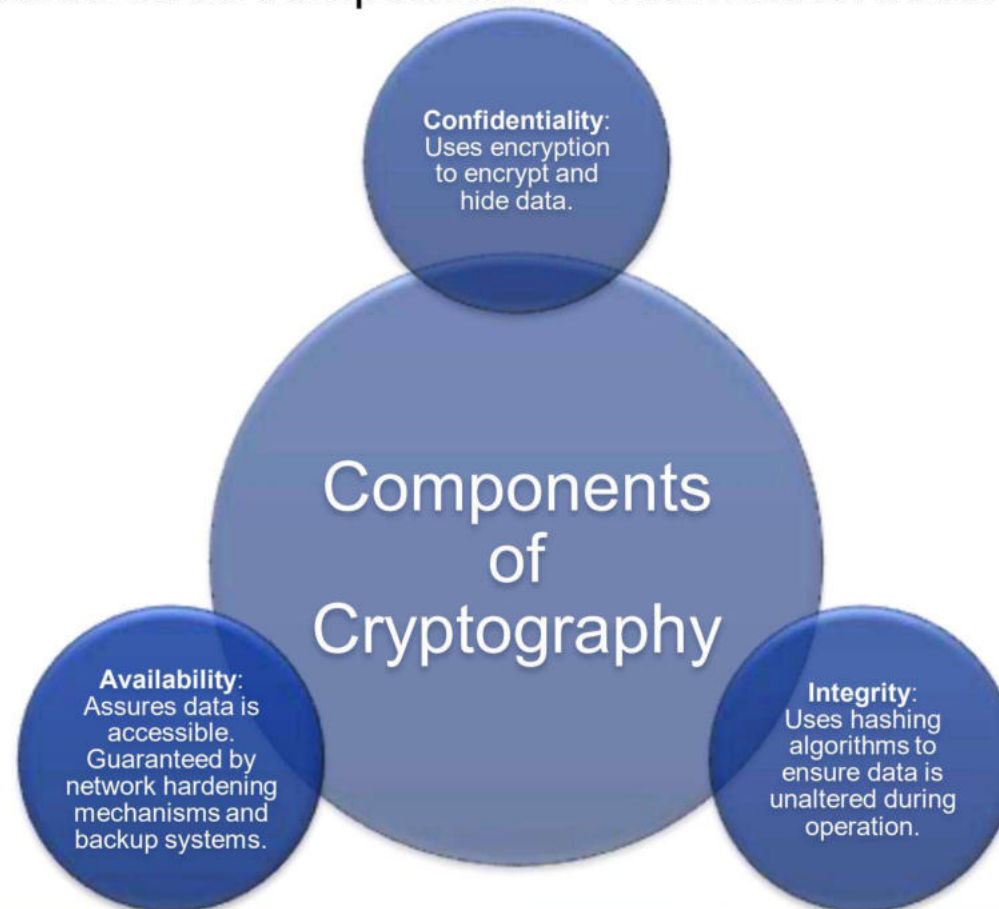
1. Hacker builds a network of infected machines
 - A network of infected hosts is called a botnet.
 - The compromised computers are called zombies.
 - Zombies are controlled by handler systems.
2. Zombie computers continue to scan and infect more targets
3. Hacker instructs handler system to make the botnet of zombies carry out the DDoS attack

Confidentiality, Integrity, Availability مهم

In addition to preventing and denying malicious traffic, network security professionals must also ensure that data is protected.

Cryptography, the study and practice of hiding information, is used extensively in modern network security.

Cryptography ensures three components of information security:



Network Security Domains مهم

- Network professional must understand network security and also be familiar with the organizations dedicated to network security, as well as the 12 network security domains.
- Domains provide a framework for discussing network security.
- There are 12 network security domains specified by ISO/IEC27002:
 - Risk assessment
 - Security policy
 - Organization of information security
 - Asset management
 - Human resources security
 - Physical and environmental security
 - Communications and operations management
 - Information systems acquisition, development, and maintenance
 - Access control
 - Information security incident management
 - Business continuity management
 - Compliance

Defending the Network

Best practices:

- Develop a written security policy.
- Educate employees about the risks of social engineering, and develop strategies to validate identities over the phone, via email, or in person.
- Control physical access to systems.
- Use strong passwords and change them often.
- Encrypt and password-protect sensitive data.
- Implement security hardware and software.
- Perform backups and test the backed up files on a regular basis.
- Shut down unnecessary services and ports.
- Keep patches up-to-date by installing them weekly or daily to prevent buffer overflow and privilege escalation attacks.
- Perform security audits to test the network.



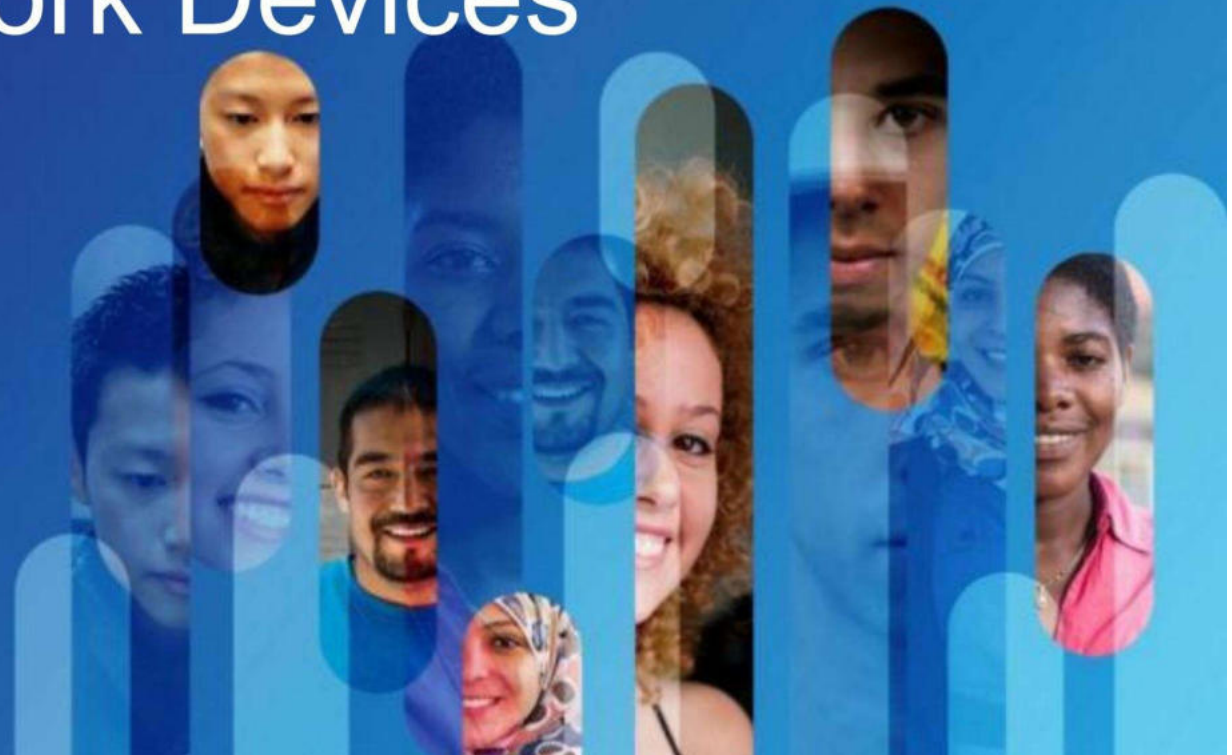
Cisco Networking Academy
Mind Wide Open

Chapter 2:

Securing Network Devices

CCNA Security v2.0

Sadeq Alsoufi



Edge Router Security Approaches مهم جداً

The edge router implementation varies depending on the size of the organization and the complexity of the required network design.

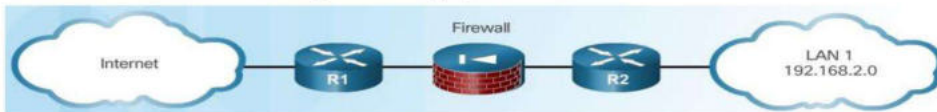
Router implementations can include a single router protecting an entire inside network or a router functioning as the first line of defense in a defense-in-depth approach.

Single Router Approach



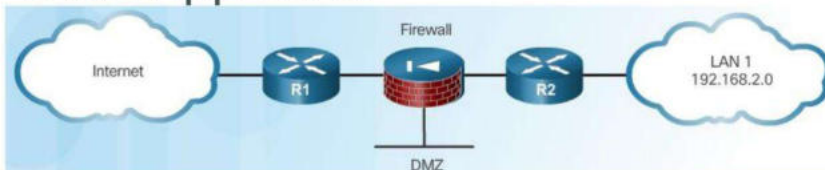
All security policies are configured on this device. This is more commonly deployed in smaller site implementations, such as branch and small office

Defense in Depth Approach



It uses multiple layers of security prior to traffic entering the protected LAN.

DMZ Approach



A variation of the defense-in-depth approach

Three Areas of Router Security مهم جداً

Three areas of router security must be maintained:

Physical Security

Place the router and physical devices that connect to it in a secure locked room that is accessible only to authorized personnel, is free of electrostatic or magnetic interference, has fire suppression, and has temperature and humidity controls.

Install an uninterruptible power supply (UPS) or diesel backup power generator, and keep spare components available..

Operating System Security

- Configure the router with the maximum amount of memory possible. The availability of memory can help mitigate risks to the network from some denial of service (DoS) attacks while supporting the widest range of security services.

- Use the latest, stable version of the operating system that meets the feature specifications of the router or network device.

Keep a secure copy of router operating system images and router configuration files as backups.

Router Hardening

Secure administrative control.

Disable unused ports and interfaces.

Disable unnecessary services.



Secure Administrative Access مهم جداً

Securing administrative access is an extremely important security task.

Tasks:

- Restrict device accessibility
- Log and account for all access
- Authenticate access
- Authorize actions
- Present legal notification
- Ensure the confidentiality of data :

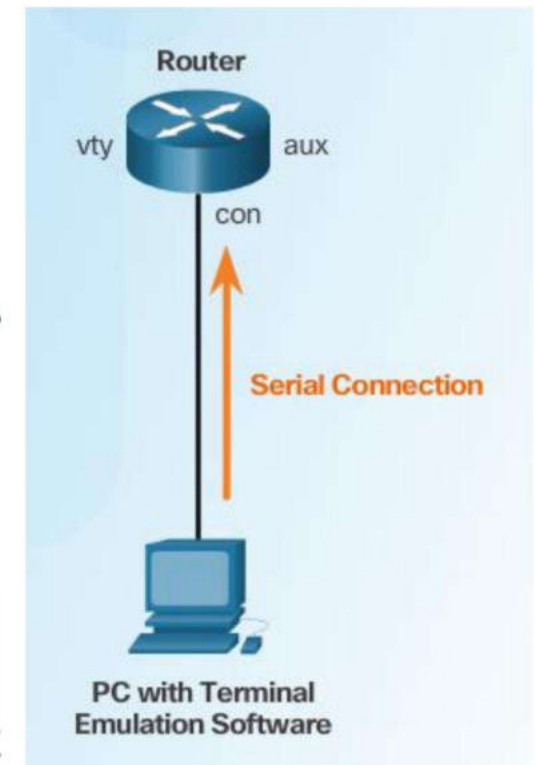
Protect locally stored and sensitive data from being viewed and copied.

Secure Local and Remote Access ^{مهم جداً}

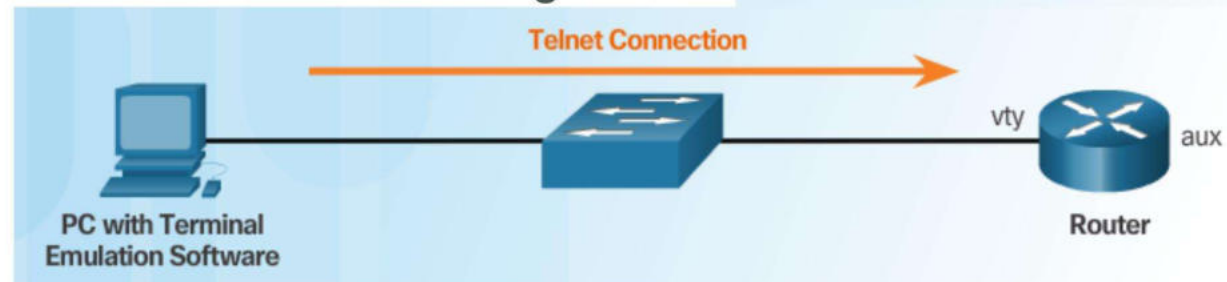
Precautions should be taken when accessing the network remotely:

- Encrypt all traffic between the administrator computer and the router.(i.e SSH)
- Establish a dedicated management network.
- Configure a packet filter to allow only the identified administration hosts and preferred protocols to access the router.
- Configure and establish a VPN connection to the local network before connecting to a router management interface.

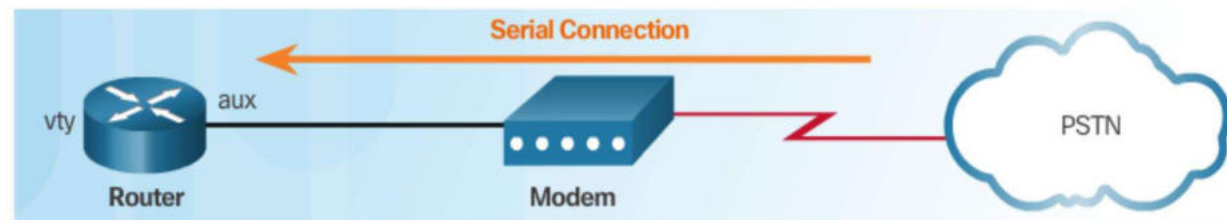
Local Access



Remote Access Using Telnet



Remote Access Using Modem and Aux Port

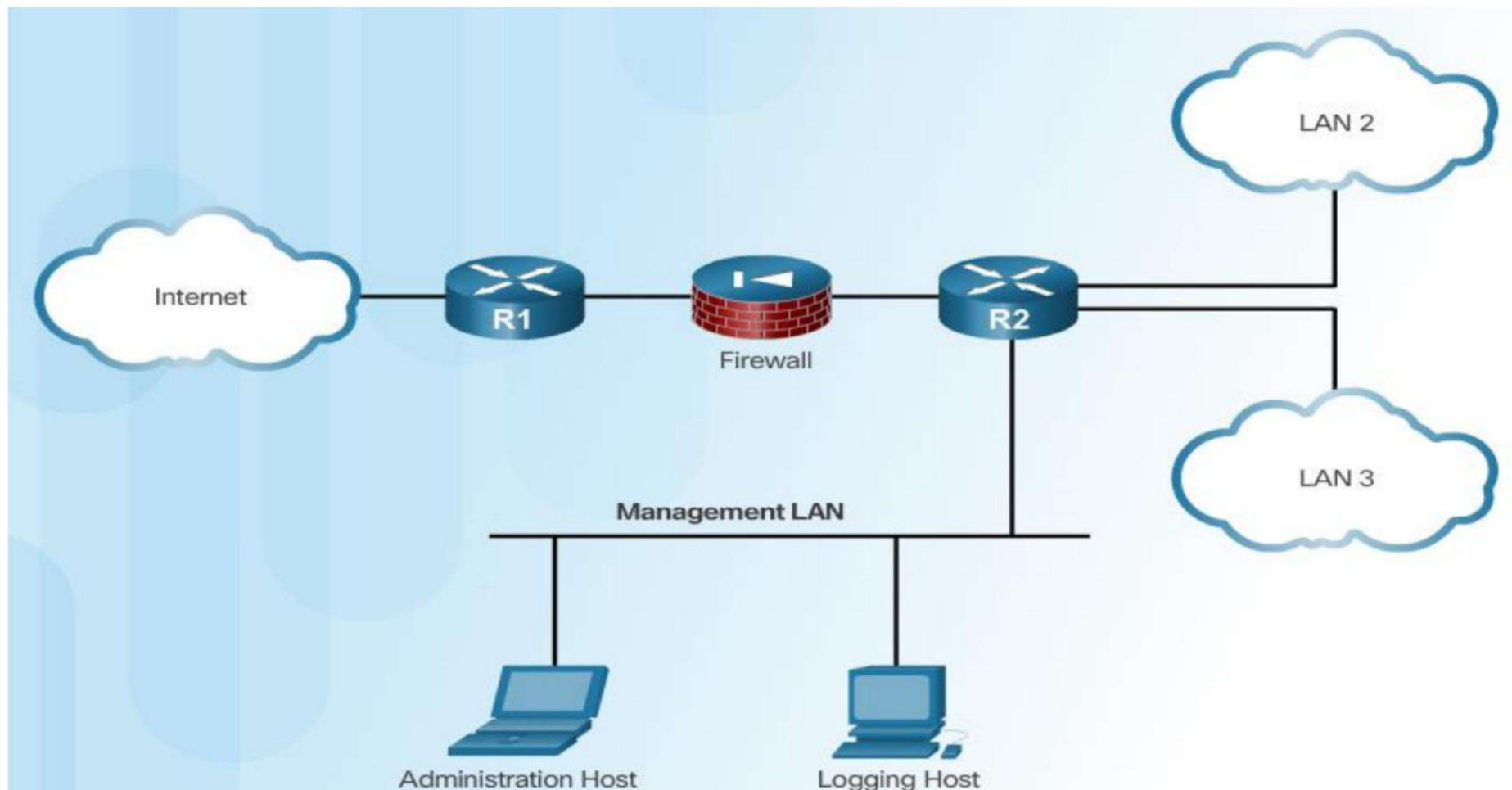


Secure Local and Remote Access (Cont.)



Dedicated Management Network

The management network should include only identified administration hosts and connections to a dedicated interface on the router.



Topic 2.2.1: Configuring Privilege Levels



Limiting Command Availability مهم جداً

Privilege levels:

- Level 0: Predefined for user-level access privileges.
- Level 1: Default level for login with the router prompt.
- Level 2-14: May be customized for user-level privileges.
- Level 15: Reserved for the enable mode privileges.

Levels of access commands:

- User EXEC mode (privilege level 1)
Lowest EXEC mode user privileges
Only user-level command available at the router> prompt
- Privileged EXEC mode (privilege level 15)
All enable-level commands at the router# prompt

Privilege Level Syntax

Router(config)#

```
privilege mode {level level | reset} command
```

Command	Description
<i>mode</i>	Specifies the configuration mode. Use the privilege ? command to see a complete list of router configuration modes available on your router.
level	(Optional) Enables setting a privilege level with a specified command.
<i>level</i>	(Optional) The privilege level that is associated with a command. You can specify up to 16 privilege levels, using numbers 0 to 15.
reset	(Optional) Resets the privilege level of a command.
<i>command</i>	(Optional) Argument to use when you want to reset the privilege level.

Cisco IOS software has two methods of providing infrastructure access:

privilege level and role-based CLI.

Both methods help determine who should be allowed to connect to the device and what that person should be able to do with it.

Limitations of Privilege Levels

- No access control to specific interfaces, ports, logical interfaces, and slots on a router
- Commands available at lower privilege levels are always executable at higher privilege levels
- Commands specifically set at higher privilege levels are not available for lower privilege users
- Assigning a command with multiple keywords allows access to all commands that use those
- **Note:** If an administrator must create a user account that has access to most but not all commands, privilege exec statements need to be configured for every command that must be executed at a privilege level lower than 15

Role-Based CLI Access

For example:

- Security operator privileges

- Configure AAA

- Issue **show** commands

- Configure firewall

- Configure IDS/IPS

- Configure NetFlow

- WAN engineer privileges

- Configure routing

- Configure interfaces

- Issue **show** commands

Cisco introduced the role-based CLI access feature in Cisco IOS Release 12.3(11)T to provide more flexibility than privilege levels allow,

Role-based CLI access enables the network administrator to create different views of router configurations for different users.

Each view defines the CLI commands that each user can access.

Role-Based Views

Role-based CLI provides three types of views:

Root View

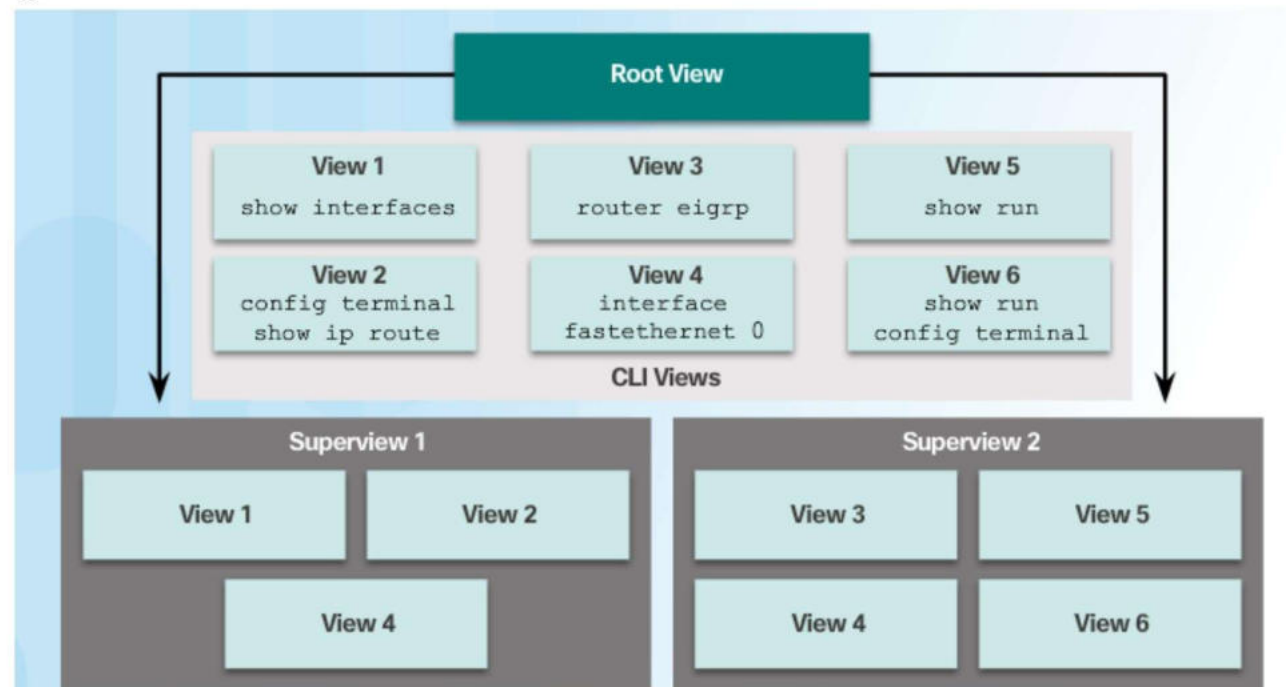
Only a root view user can configure a new view and add or remove commands from the existing views.

CLI View

A specific set of commands can be bundled into a CLI view. Unlike privilege levels, a CLI view has no command hierarchy and no higher or lower views.

Superview

A superview consists of one or more CLI views. Administrators can define which commands are accepted and which configuration information is visible.



Superviews contain Views but not commands. Two Superviews can use the same View. For example, both Superview 1 and Superview 2 can have CLI View 4 placed inside.

Topic 2.3.1: Securing Cisco IOS Image and Configuration Files



Cisco IOS Resilient Configuration Feature

The Cisco IOS Resilient Configuration feature allows for faster recovery if someone reformats flash memory or erases the startup configuration file in NVRAM.

When a Cisco IOS image is secured, the resilient configuration feature denies all requests to copy, modify, or delete it.

The secure copy of the startup configuration is stored in flash along with the secure IOS image.

This set of Cisco IOS image and router running configuration files is referred to as the bootset.

Two global configurations commands are available to configure the Cisco IOS resilient configuration features: `secure boot-image` and `secure boot-config`.

Cisco IOS Resilient Configuration Facts

- The configuration file in the primary bootset is a copy of the running configuration that was in the router when the feature was first enabled.
- The feature secures the smallest working set of files to preserve persistent storage space. No extra space is required to secure the primary Cisco IOS image file.
- The feature automatically detects image or configuration version mismatch.
- Only local storage is used for securing files, eliminating scalability maintenance challenges from storing multiple images and configurations on TFTP servers.
- The feature can be disabled only through a console session.
- The feature is only available for systems that support a PCMCIA Advanced Technology Attachment (ATA) flash interface.

Configuring Secure Copy

The Cisco IOS Resilient feature provides a method for securing the IOS image and configuration files locally on the device.

Use the Secure Copy Protocol (SCP) feature to remotely copy these files.

SCP provides a secure and authenticated method for copying router configuration or router image files to a remote location.

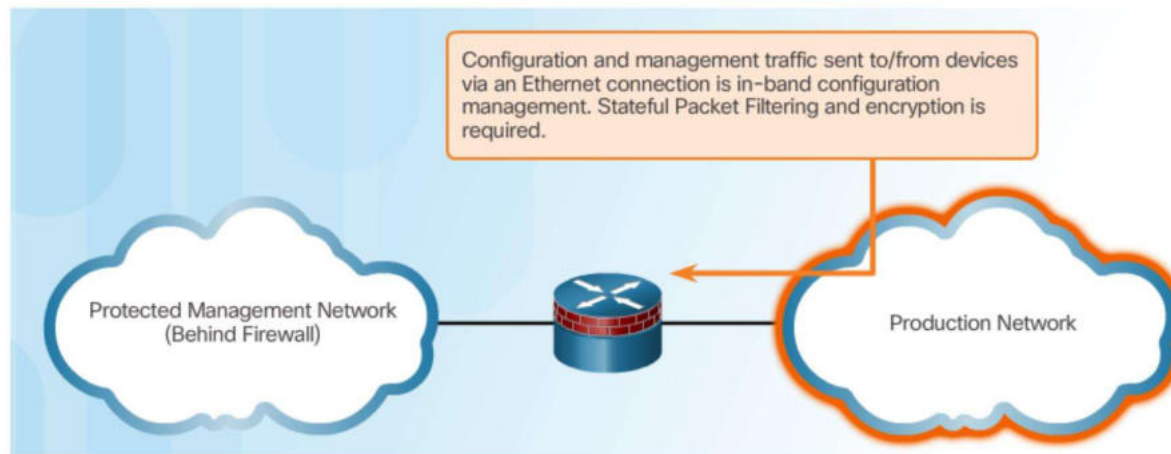
Configure the router for server-side SCP with local AAA:

1. Configure SSH
2. Configure at least one user with privilege level 15
3. Enable AAA
4. Specify that the local database is to be used for authentication
5. Configure command authorization
6. Enable SCP server-side functionality

Topic 2.3.2: Secure Management and Reporting



Determining the Type of Management Access

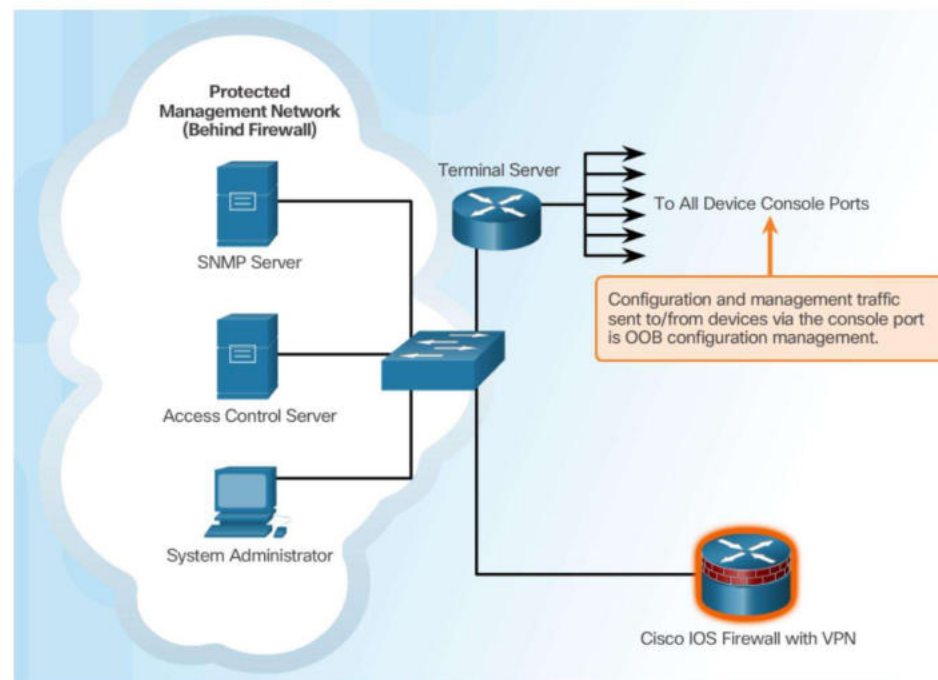


In-Band Management:

- Apply only to devices that need to be managed or monitored
- Use IPsec, SSH, or SSL when possible
- Decide whether the management channel need to be open at all time

Out-of-Band (OOB) Management:

- Provide highest level of security
- Mitigate the risk of passing management protocols over the production network



Syslog Message



Cisco devices produce syslog messages as a result of network events. Every syslog message contains a severity level and a facility.

Security Levels

	Level	Keyword	Description	Definition
Highest Level	0	emergencies	System is unusable	LOG_EMERG
	1	alerts	Immediate action is needed	LOG_ALERT
	2	critical	Critical conditions exist	LOG_CRIT
	3	errors	Error conditions exist	LOG_ERR
	4	warnings	Warning conditions exist	LOG_WARNING
	5	notifications	Normal but significant condition	LOG_NOTICE
	6	informational	Informational messages only	LOG_INFO
Lowest Level	7	debugging	Debugging messages	LOG_DEBUG

The smaller numerical levels are the more critical syslog alarms. The severity level of the messages can be set to control where each type of message is displayed (i.e console ..)

Example Severity Levels

Syslog Level and Name	Definition	Example
0 LOG_EMERG	A panic condition normally broadcast to all users	Cisco IOS software could not load
1 LOG_ALERT	A condition that should be corrected immediately, such as a corrupted system database	Temperature too high
2 LOG_CRIT	Critical conditions; for example, device errors	Unable to allocate memory
3 LOG_ERR	Errors	Invalid memory size
4 LOG_WARNING	Warning messages	Crypto operation failed
5 LOG_NOTICE	Non-error conditions that may require special handling	Interface changed state, up or down
6 LOG_INFO	Informational messages	Packet denied by ACL
7 LOG_DEBUG	Messages that contain information that is normally used only when debugging a program	Packet type invalid

Syslog levels zero to four are messages about software or hardware functionality.

Syslog levels five and six are for notifications and informational messages.

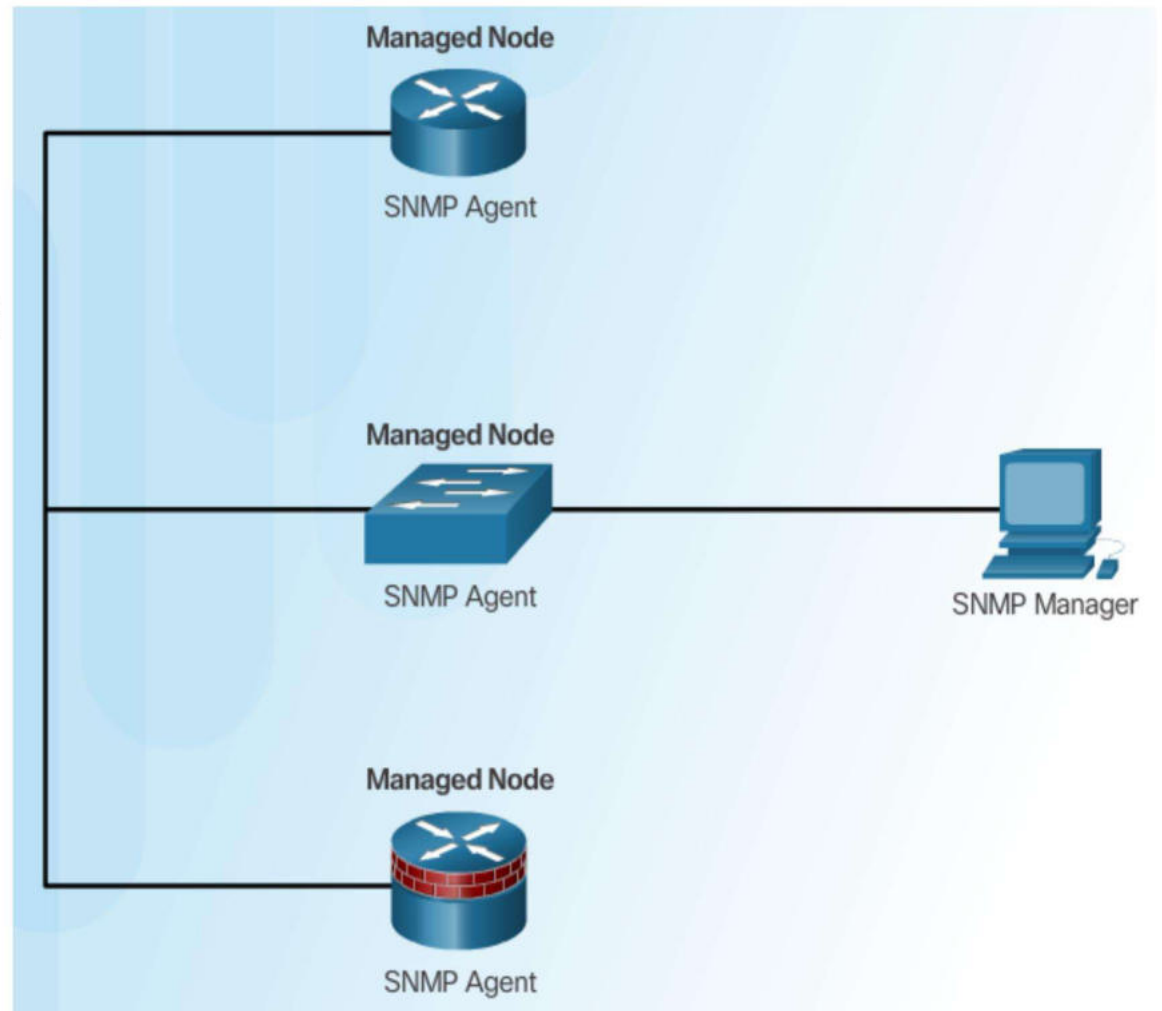
Topic 2.3.4: Using SNMP for Network Security



Introduction to SNMP

SNMP consists of three elements relevant to the Network Management System (NMS):

SNMP manager.
SNMP agents (managed node).
Management Information Base (MIB)



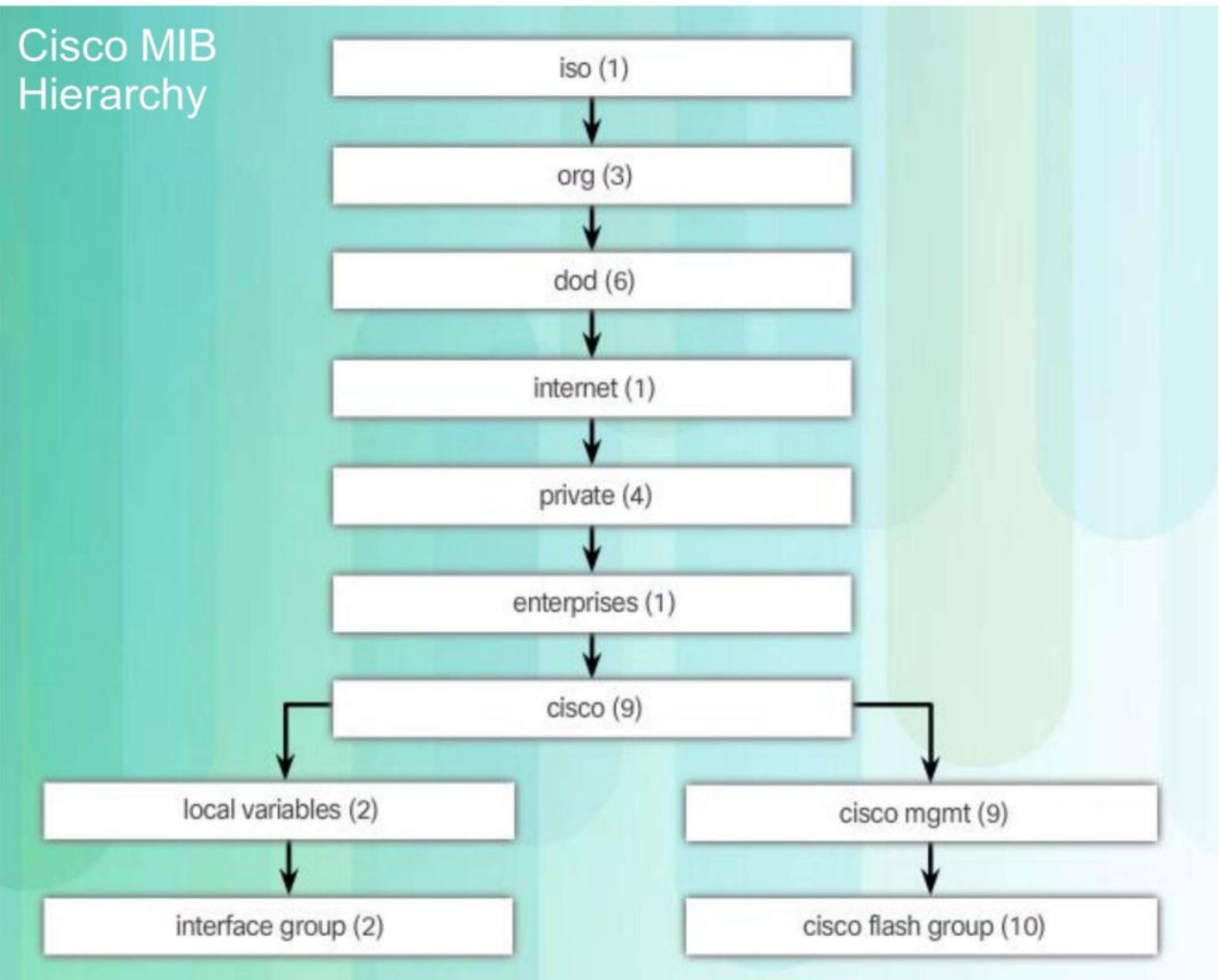
Management Information Base

SNMP set, get, and trap messages all have access to create and change the information in the MIB.

This information is organized hierarchically so that SNMP can access it quickly.

Each piece of information within the MIB is given an object ID (OID).

The MIB organizes the OIDs based on RFC standards into a hierarchy of OIDs

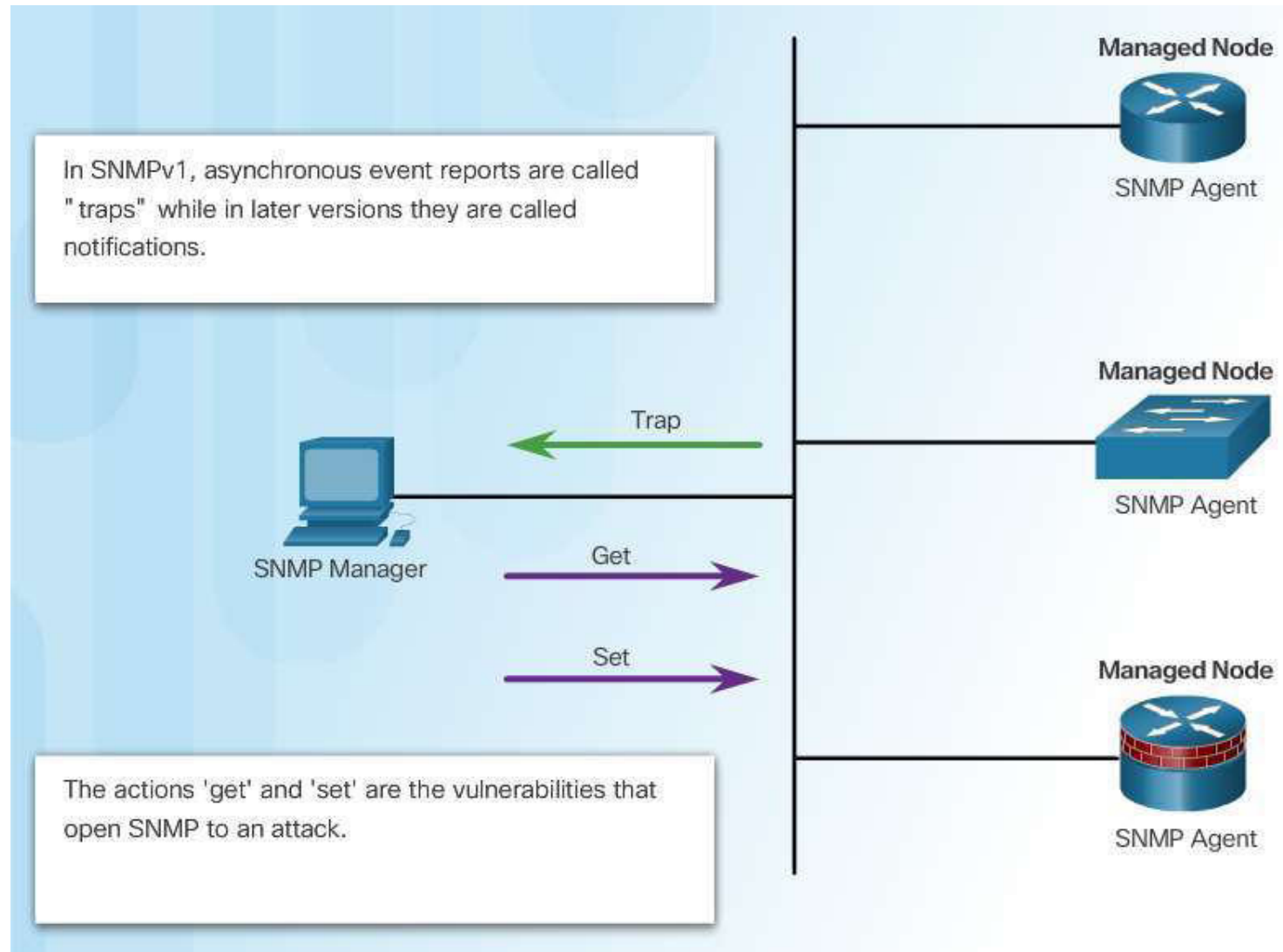


SNMP Versions مهم جداً

Model	Level	Authentication	Encryption	Result
SNMPv1	noAuthNoPriv	Community string	No	Uses a community string match for authentication.
SNMPv2c	noAuthNoPriv	Community string	No	Uses a community string match for authentication.
SNMPv3	noAuthNoPriv	Username	No	Uses a username match for authentication (an improvement over SNMPv2c).
SNMPv3	authNoPriv	Message Digest 5 (MD5) or Secure Hash Algorithm (SHA)	No	Provides authentication based on the HMAC-MD5 or HMAC-SHA algorithms.
SNMPv3	authPriv (requires the cryptographic software image)	MD5 or SHA	Data Encryption Standard (DES) or Advanced Encryption Standard (AES)	Provides authentication based on the HMAC-MD5 or HMAC-SHA algorithms. Allows specifying the User-based Security Model (USM) with these encryption algorithms: • DES 56-bit encryption in addition to authentication based on the CBC-DES (DES-56) standard. • 3DES 168-bit encryption • AES 128-bit, 192-bit, or 256-bit encryption

SNMP Vulnerabilities

The requests and notifications are not authenticated or encrypted.



Topic 2.3.5: Using NTP



Network Time Protocol مهم

To ensure that log messages are accurately timestamped, clocks on hosts and network devices must be synchronized and maintained.

Typically, the date and time settings of the router can be set using one of two methods:

Manually editing the date and time
Configuring the Network Time Protocol (NTP)

```
R1# clock set 10:28:00 DEC 16 2008
R1#
*Dec 16 10:28:00.000: %SYS-6-CLOCKUPDATE: System clock
has been updated from 16:07:17 UTC Tue Dec 16 2008 to
10:28:00 UTC Tue Dec 16 2008, configured from console
by console.
R1#
```

س/ ماهو البروتكول المسؤول عن الوقت؟

Topic 2.5.1: Routing Protocol Authentication





Cisco Networking Academy
Mind Wide Open

Chapter 3:

Authentication, Authorization, and Accounting

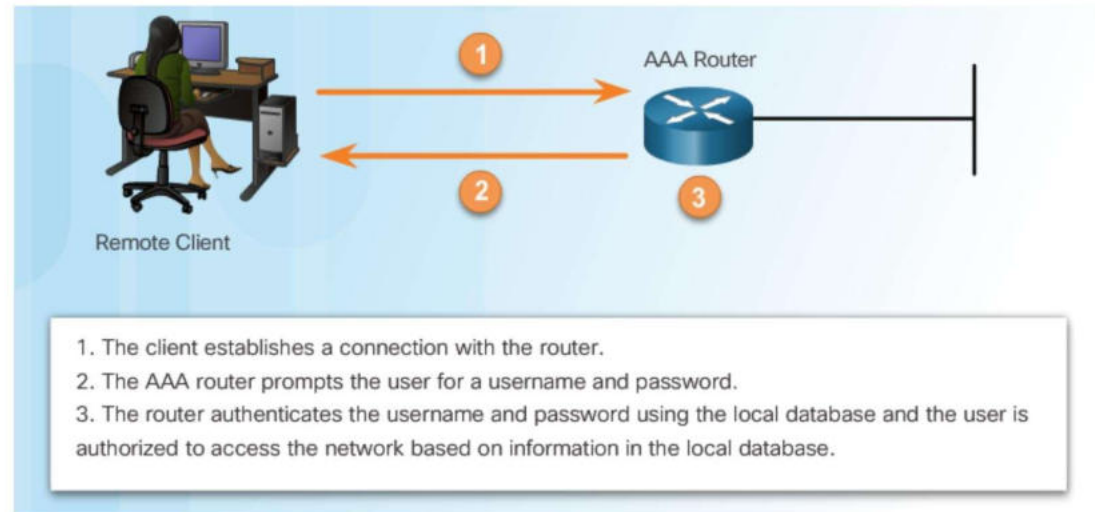
CCNA Security v2.0



Authentication Modes

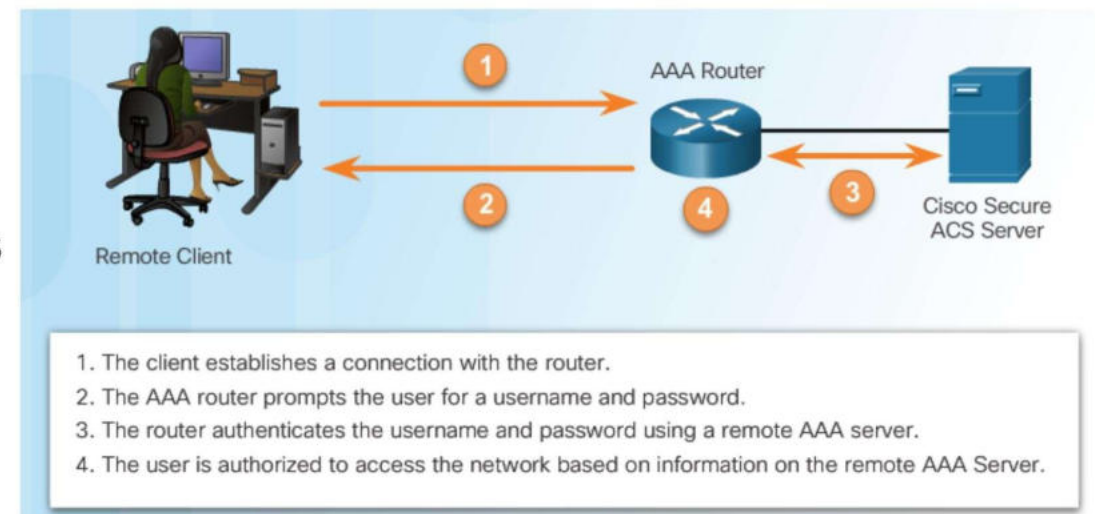
Local AAA Authentication

uses a local database for authentication



Server-Based AAA Authentication

The central AAA server contains the usernames and password for all users



Topic 3.3.2: Server-Based AAA Communication Protocols



Introducing TACACS+ and RADIUS مهم جداً

TACACS+ and RADIUS are both authentication protocols that are used to communicate with AAA servers.

	TACACS+	RADIUS
Functionality	Separates AAA according to the AAA architecture, allowing modularity of the security server implementation	Combines authentication and authorization but separates accounting, allowing less flexibility in implementation than TACACS+
Standard	Mostly Cisco supported	Open/RFC standard
Transport Protocol	TCP	UDP
CHAP	Bidirectional challenge and response as used in Challenge Handshake Authentication Protocol (CHAP)	Unidirectional challenge and response from the RADIUS security server to the RADIUS client
Protocol Support	Multiprotocol support	No ARA, no NetBEUI
Confidentiality	Entire packet encrypted	Password encrypted
Customization	Provides authorization of router commands on a per-user or per-group basis	Has no option to authorize router commands on a per-user or per-group basis
Accounting	Limited	Extensive

Introduction to Server-Based AAA Authorization



Authentication vs. Authorization

- **Authentication** ensures a device or end-user is legitimate
- **Authorization** allows or disallows authenticated users access to certain areas and programs on the network.

TACACS+ vs. RADIUS

- **TACACS+** separates authentication from authorization
- **RADIUS** does **not** separate authentication from authorization



Cisco Networking Academy
Mind Wide Open

Chapter 4: كامل مهم ما عدا ما يخص العملي Implementing Firewall Technologies

CCNA Security v2.0

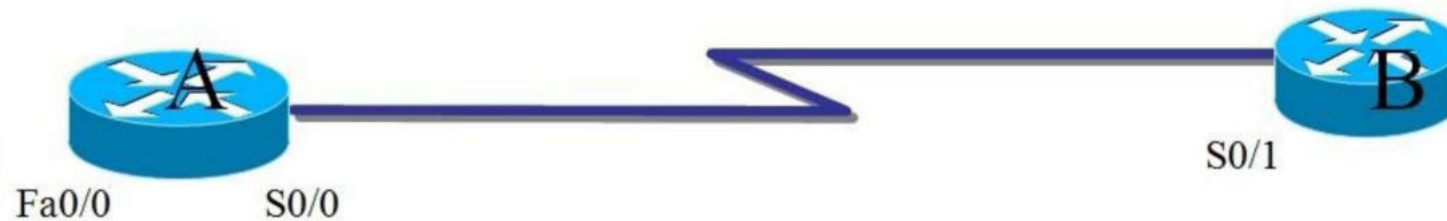


كامل مهم ماعدا مايخص العملي

What Are Access Lists?

- ▶ An access list is a sequential series of commands or filters.
- ▶ These lists tell the router what types of packets to:
 - ❑ accept or
 - ❑ deny
- ▶ Acceptance and denial can be based on specified conditions.
- ▶ ACLs applied on the router's interfaces.

Access List Overview



1. Position: interface of the router
2. condition: Permit/deny
- 3 direction: In /Out
4. Arrangement of the statement

Access List Overview

172.16.20.1

Deny 172.16.20.1 only

I

A

C

B

Access-list 5 permit any

Access-list 5 deny 172.16.20.1

Access-list 5 deny 172.16.20.1

Access-list 5 permit any

Permit 172.16.20.1 only

A

C

B

Access-list 5 deny any

Access-list 5 permit 172.16.20.1

Access-list 5 permit 172.16.20.1

Access-list 5 deny any

Access List Overview

5- Default of the Access Control List (ACL)

A	Deny C	B
Access-list 5 deny any		Access-list 5 permit 172.16.20.1
Access-list 5 permit 172.16.20.1		

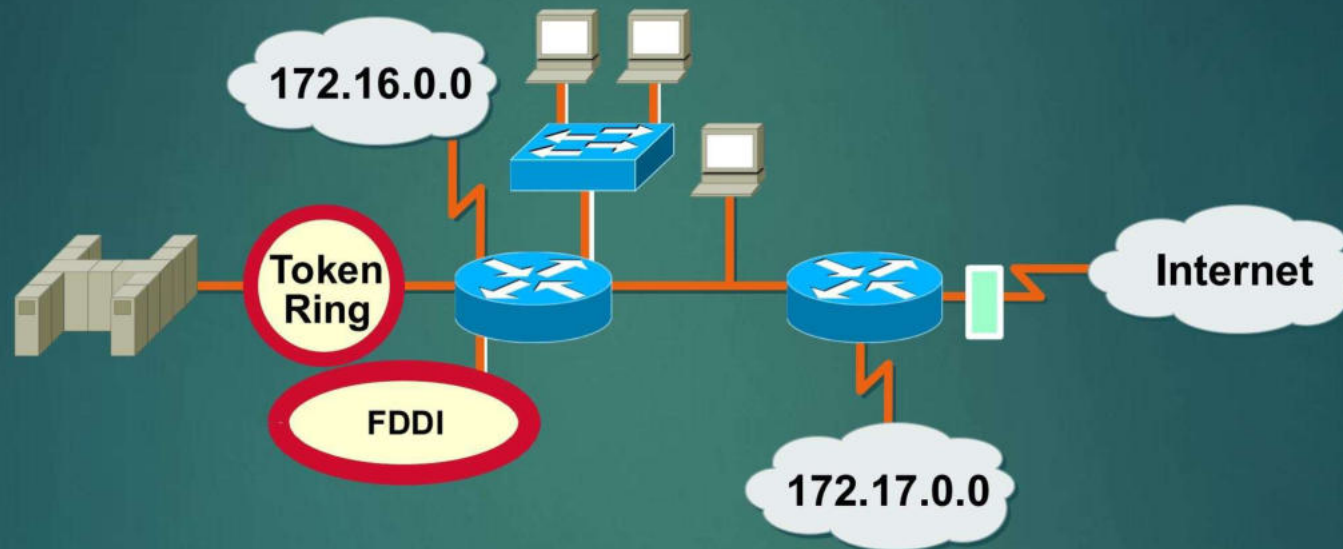
6- The ACL must contain at least one permit statement

Deny 172.16.20.1 only

Access-list 9 deny 172.16.20.1

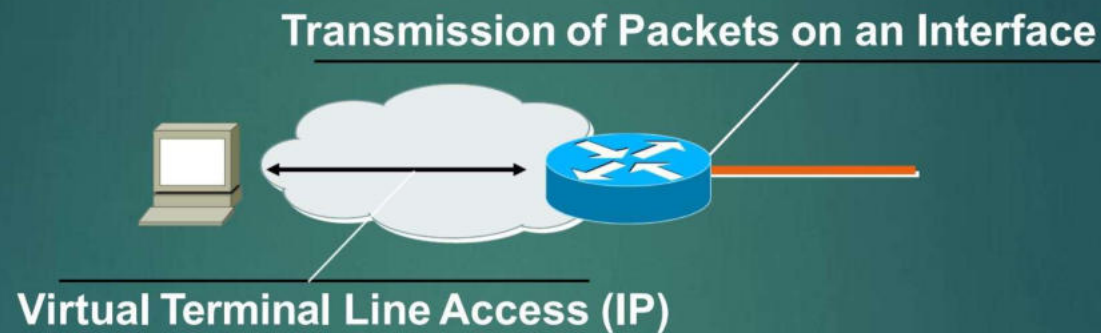
Access-list 9 permit any

Why Use Access Lists?



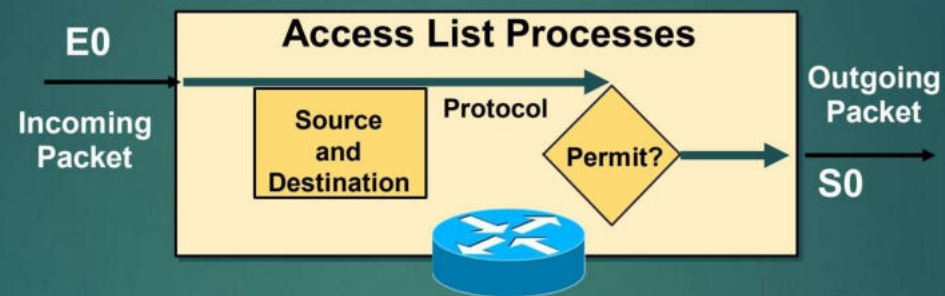
- ▶ Manage IP traffic as network access grows.
- ▶ Filter packets as they pass through the router.

Access List Applications



- ▶ Permit or deny packets moving through the router.
- ▶ Permit or deny vty access to or from the router.
- ▶ Without access lists, all packets could be transmitted onto all parts of your network.

What Are Access Lists?



- **Standard**
 - Checks source address
 - Generally permits or denies entire protocol suite
- **Extended**
 - Checks source and destination address
 - Generally permits or denies specific protocols
- **Inbound or outbound**

Access List Command Overview

Step 1: Set parameters for this access list test statement (which can be one of several statements).

```
Router(config)#access-list access-list-number  
{permit | deny} {test conditions}
```

Step 2: Enable an interface to use the specified access list.

```
Router(config-if){protocol} access-group  
access-list-number {in | out}
```

Standard Access list

Permit or deny all TCP stack
1-99 & 1300- 1999

Extended Access list

permit/deny specific application
100-199 & 2000- 2699

Standard IP Access List Configuration

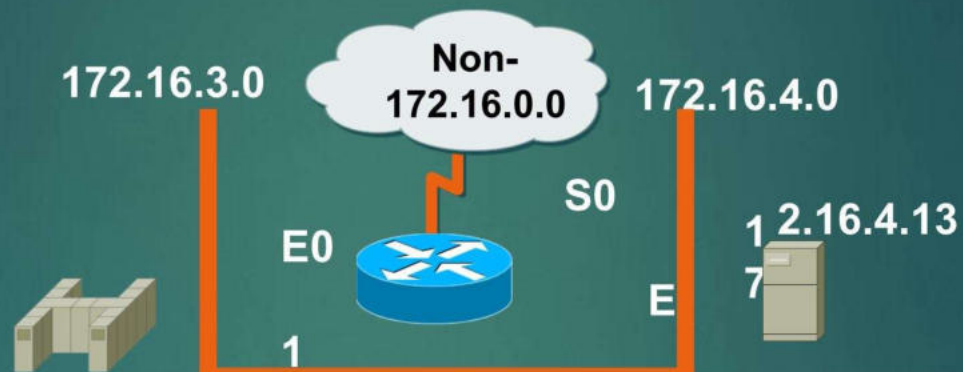
```
Router(config)#access-list access-list-number  
{permit | deny | remark} source [mask]
```

- Sets parameters for this list entry
- IP standard access lists use 1 to 99
- Default wildcard mask = 0.0.0.0
- no access-list *access-list-number* removes entire access list
- remark option lets you add a description for the access list

```
Router(config-if)#ip access-group  
access-list-number {in | out}
```

- ▶ Activates the list on an interface
- ▶ Sets inbound or outbound testing
- ▶ Default = outbound
- ▶ no ip access-group *access-list-number* removes access list from the interface

Standard IP Access List Example



```
access-list 1 permit 172.16.0.0 0.0.255.255  
(implicit deny all - not visible in the list)  
(access-list 1 deny 0.0.0.0 255.255.255.255)
```

Extended IP Access List Configuration

```
Router(config)#access-list access-list-number  
{permit | deny} protocol source source-wildcard  
[operator port] destination destination-wildcard  
[operator port] [established] [log]
```

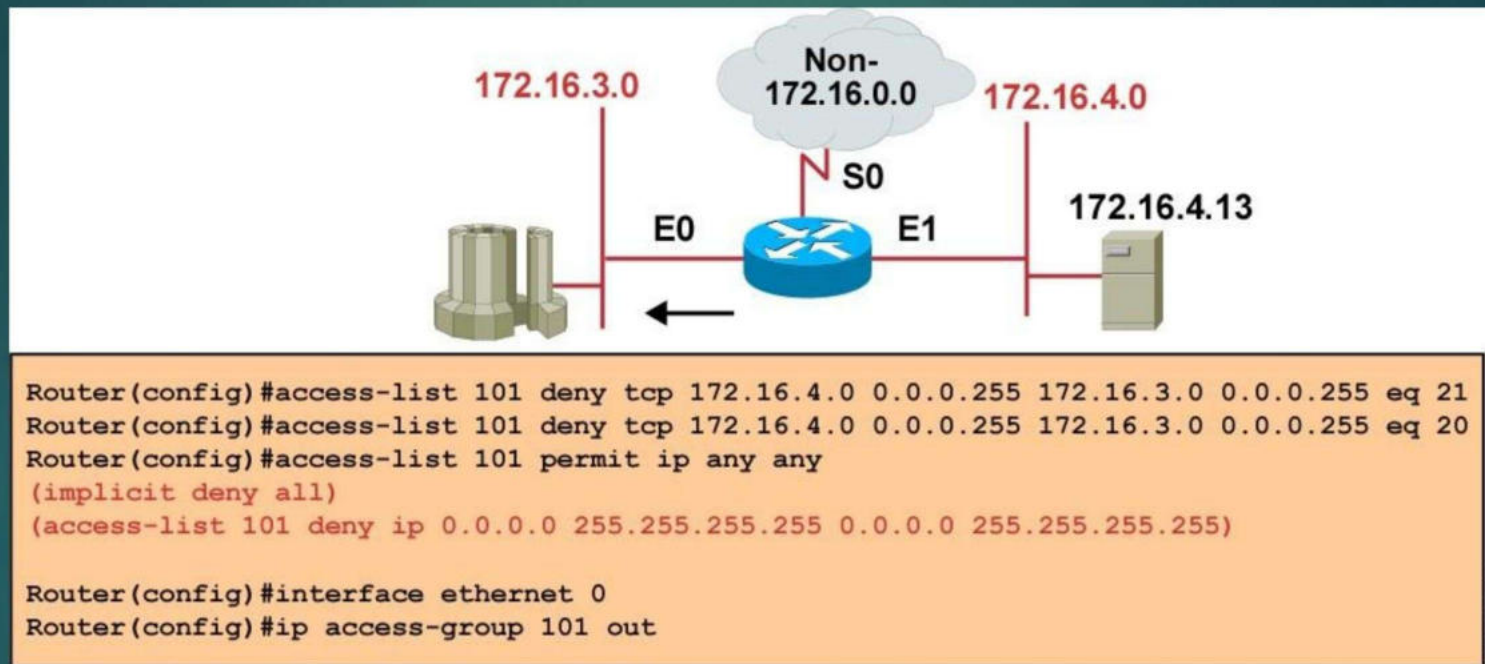
- Sets parameters for this list entry

```
Router(config-if)#ip access-group access-list-number {in | out}
```

- Activates the extended list on an interface

Extended Access List : Example

1



- ▶ Deny FTP from subnet 172.16.4.0 to subnet 172.16.3.0 out of E0.
- ▶ Permit all other traffic.

Applying an ACL

Syntax - Apply an ACL
to an interface

```
Router(config-if)# ip access-group {acl-#|name} {in|out}
```

Syntax - Apply an ACL
to the VTY lines

```
Router(config-line)# access-class {acl-#|name} {in|out}
```

Example - Named Standard ACL

```
R1(config)# ip access-list standard NO_ACCESS  
R1(config-std-nacl)# deny host 192.168.11.10  
R1(config-std-nacl)# permit any  
R1(config-std-nacl)# exit  
R1(config)# interface g0/0  
R1(config-if)# ip access-group NO_ACCESS out
```

Example - Named Extended
ACL

```
R1(config)# ip access-list extended SURFING  
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 80  
R1(config-ext-nacl)# permit tcp 192.168.10.0 0.0.0.255 any eq 443  
R1(config-ext-nacl)# exit  
R1(config)# ip access-list extended BROWSING  
R1(config-ext-nacl)# permit tcp any 192.168.10.0 0.0.0.255 established  
R1(config-ext-nacl)# exit  
R1(config)# interface g0/0  
R1(config-if)# ip access-group SURFING in  
R1(config-if)# ip access-group BROWSING out
```

Applying an ACL (Cont.)

Syntax - Apply an ACL to the VTY lines

```
Router(config-line)# access-class {acl-#|name} {in|out}
```

Example - Named ACL on VTY lines with logging

```
R1(config)# ip access-list standard VTY_ACCESS
R1(config-std-nacl)# permit 192.168.10.10 log
R1(config-std-nacl)# deny any
R1(config-std-nacl)# exit
R1(config)# line vty 0 4
R1(config-line)# access-class VTY_ACCESS in
R1(config-line)# end
R1#
R1#!The administrator accesses the vty lines from 192.168.10.10
R1#
*Feb 26 18:58:30.579: %SEC-6-IPACCESSLOGNP: list VTY_ACCESS permitted 0
192.168.10.10 -> 0.0.0.0, 5 packets
R1# show access-lists
Standard IP access list VTY_ACCESS
    10 permit 192.168.10.10 log (6 matches)
    20 deny any
```

ACL Configuration Guidelines

- Create an ACL globally and then apply it.
- Ensure the last statement is an implicit `deny any` or `deny any any`.
- Remember that statement order is important because ACLs are processed top-down. As soon as a statement is matched the ACL is exited.
- Ensure that the most specific statements are at the top of the list.
- Remember that only one ACL is allowed per interface, per protocol, per direction.
- Remember that new statements for an existing ACL are added to the bottom of the ACL by default.
- Remember that router generated packets are not filtered by outbound ACLs.
- Place standard ACLs as close to the destination as possible.
- Place extended ACLs as close to the source as possible.

Editing Existing ACLs

Existing access list has three entries

```
Router# show access-lists
Extended IP access list 101
 10 permit tcp any any
 20 permit udp any any
 30 permit icmp any any
```

Access list has been edited, which adds a new ACE and replaces ACE line 20.

```
Router(config)# ip access-list extended 101
Router(config-ext-nacl)# no 20
Router(config-ext-nacl)# 5 deny tcp any any eq telnet
Router(config-ext-nacl)# 20 deny udp any any
```

Updated access list has four entries

```
Router# show access-lists
Extended IP access list 101
  5 deny tcp any any eq telnet
 10 permit tcp any any
 20 deny udp any any
 30 permit icmp any any
```

Sequence Numbers and Standard ACLs

Existing access list has four entries

```
router# show access-lists
Standard IP access list 19
 10 permit 192.168.100.1
 20 permit 10.10.10.0, wildcard bits 0.0.0.255
 30 permit 201.101.110.0, wildcard bits 0.0.0.255
 40 deny any
```

Access list has been edited, which adds a new ACE that permits a specific IP

```
router(config)# ip access-list standard 19
router(config-std-nacl)# 25 permit 172.22.1.1
```

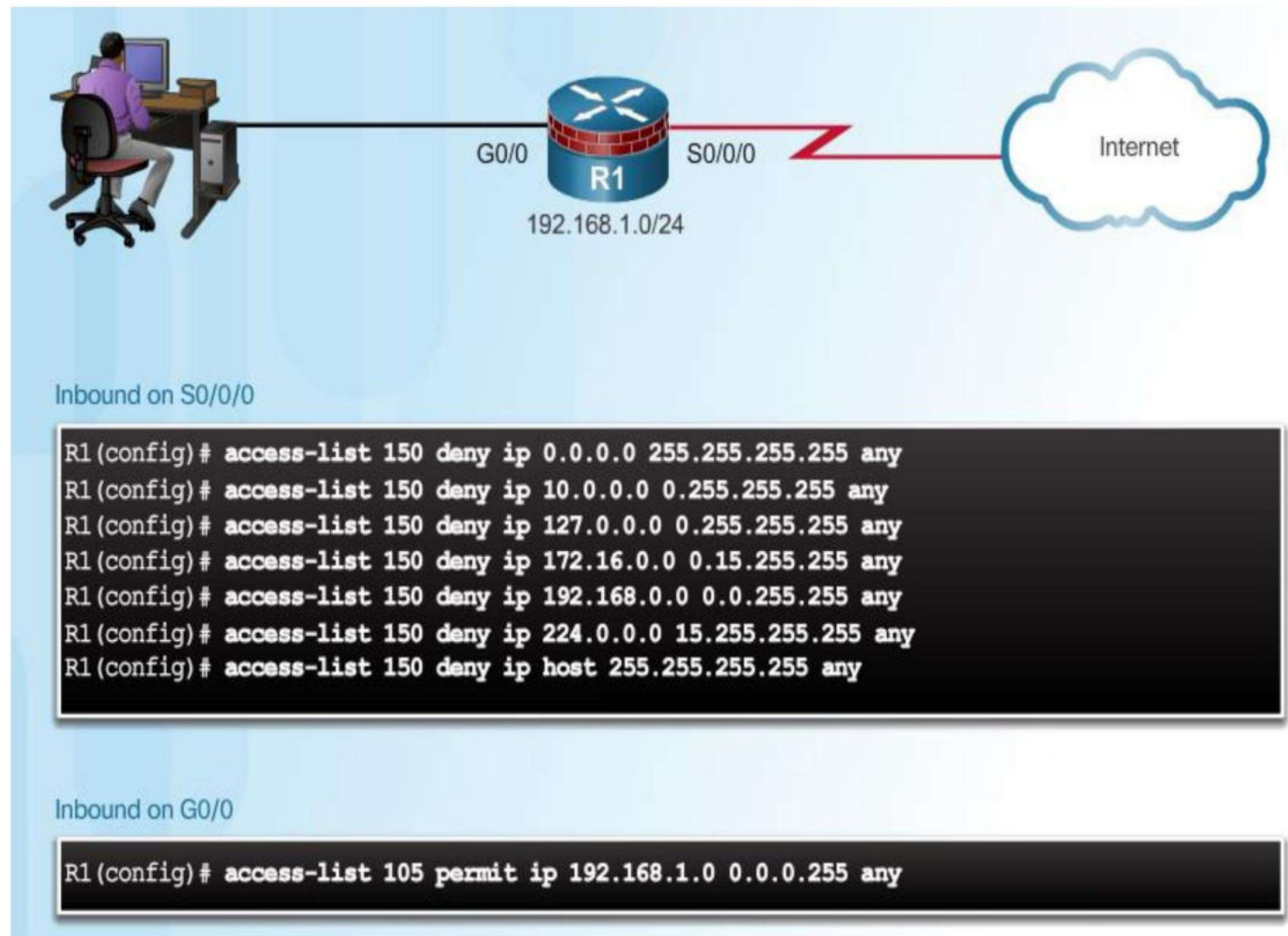
Updated access list places the new ACE before line 20

```
router# show access-lists
Standard IP access list 19
 10 permit 192.168.100.1
 25 permit 172.22.1.1
 20 permit 10.10.10.0, wildcard bits 0.0.0.255
 30 permit 201.101.110.0, wildcard bits 0.0.0.255
 40 deny any
```

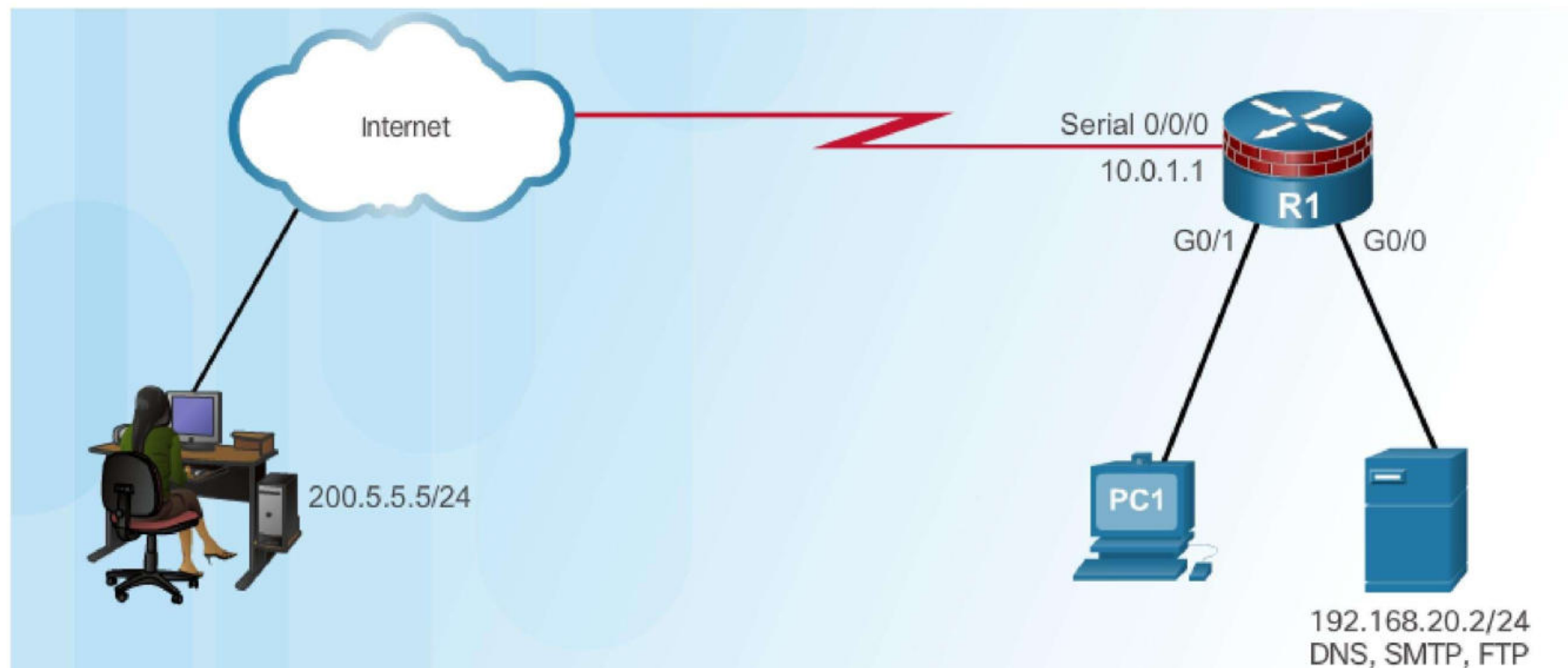
Antispoofing with ACLs

Most DoS attacks use some type of spoofing. IP address spoofing overrides the normal packet creation process by inserting a custom IP header with a different source IP address.

There are many well-known classes of IP addresses that should never be seen as source IP addresses for traffic entering an organization's network.



Permitting Necessary Traffic through a Firewall



Inbound on Serial 0/0/0

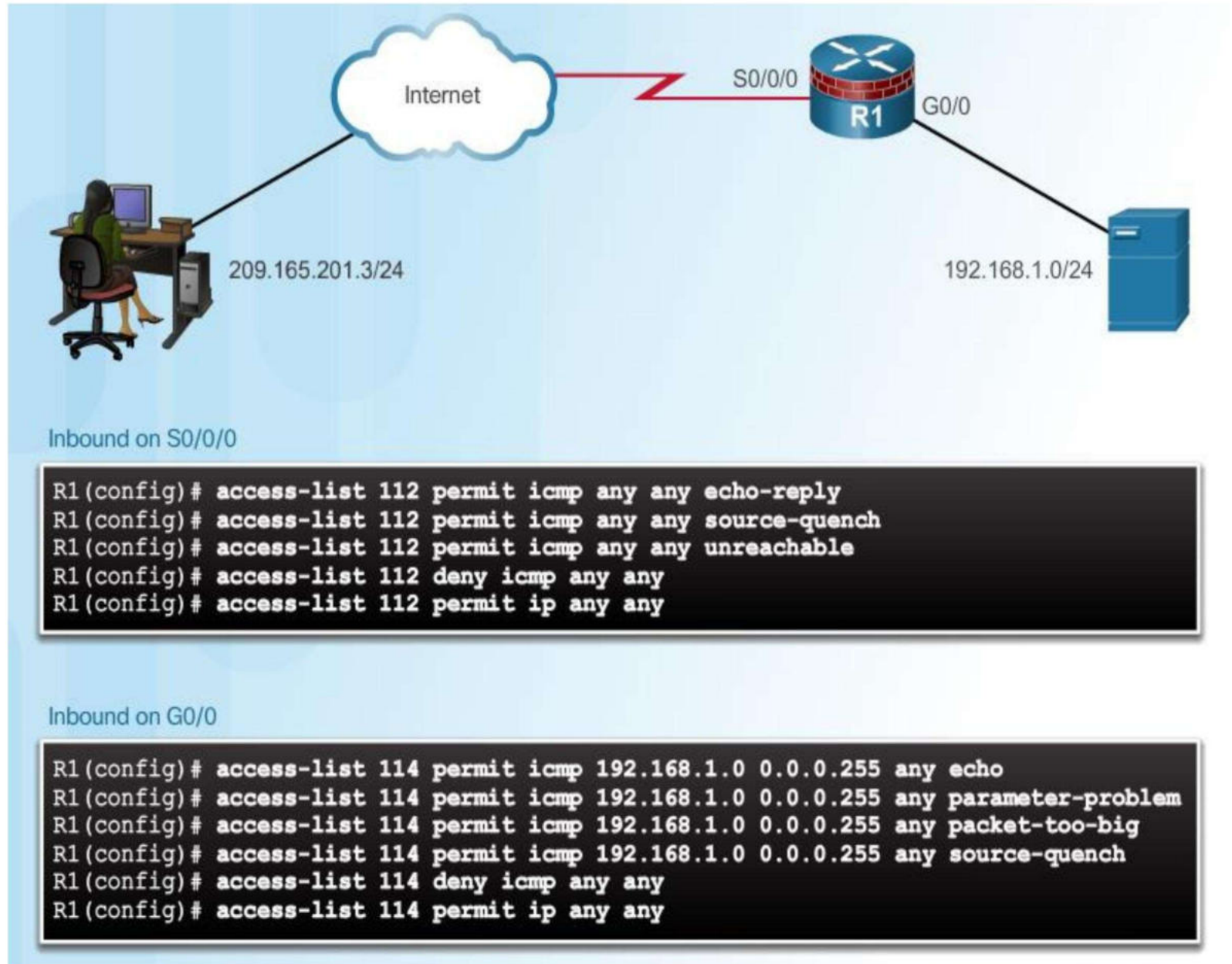
```
R1(config)# access-list 180 permit udp any host 192.168.20.2 eq domain
R1(config)# access-list 180 permit tcp any host 192.168.20.2 eq smtp
R1(config)# access-list 180 permit tcp any host 192.168.20.2 eq ftp
R1(config)# access-list 180 permit tcp host 200.5.5.5 host 10.0.1.1 eq 22
R1(config)# access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq syslog
R1(config)# access-list 180 permit udp host 200.5.5.5 host 10.0.1.1 eq snmptrap
```

Mitigating ICMP Abuse

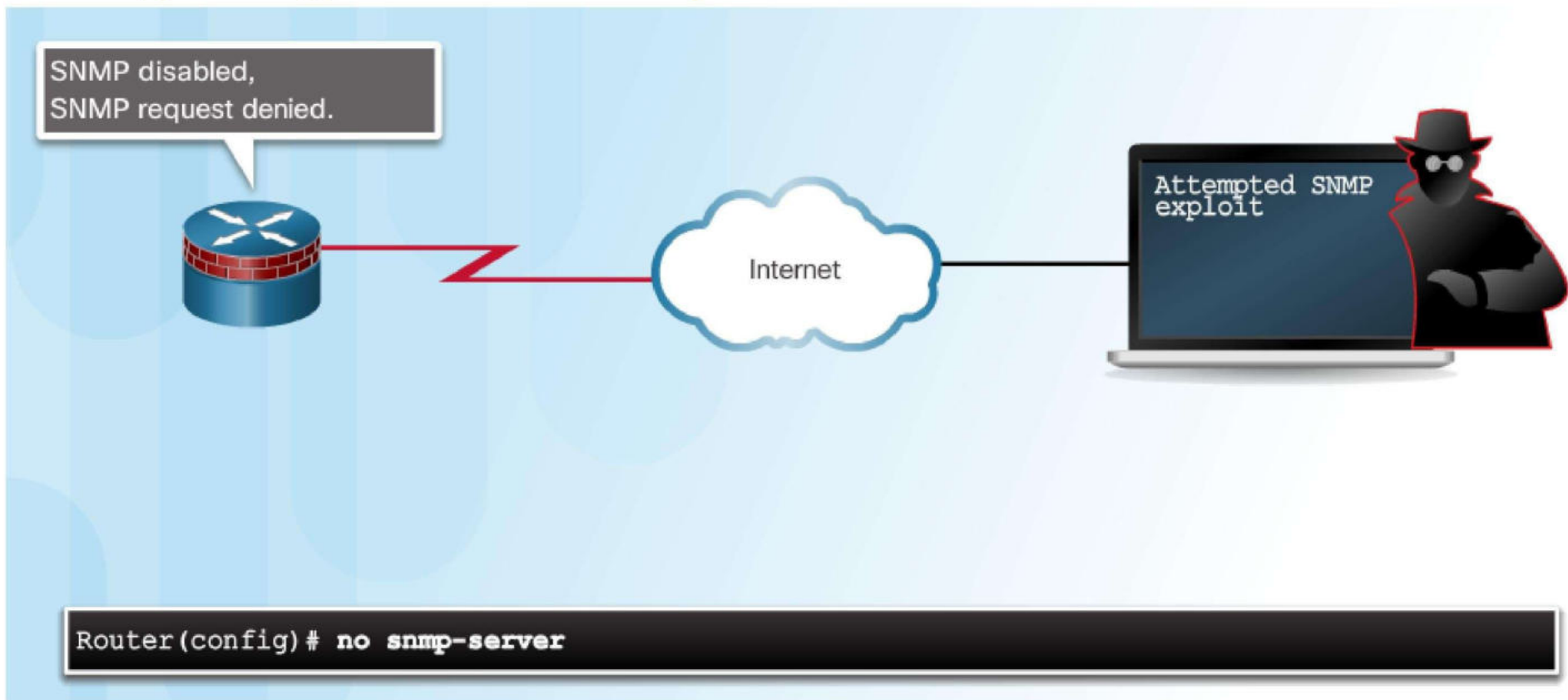
Hackers can use Internet Control Message Protocol (ICMP) echo packets (pings) to discover subnets and ICMP redirect messages to alter host routing tables.

ماهي انواع ICMP؟

Both ICMP **echo** and **redirect** messages should be blocked inbound by the router.



Mitigating SNMP Exploits



SNMP vulnerabilities can be mitigated by applying interface ACLs to filter SNMP packets from non-authorized systems.

An exploit may still be possible if the SNMP packet is sourced from an address that has been spoofed and is permitted by the ACL.

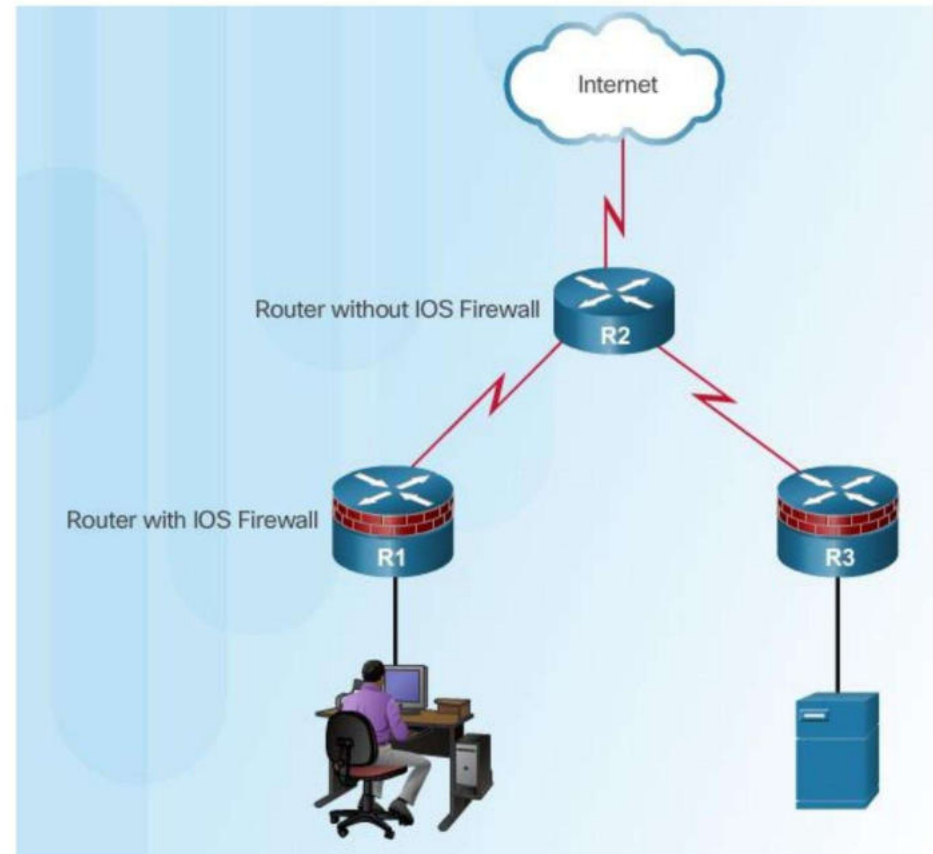
So, the most effective means of exploitation prevention is to disable the SNMP server on IOS devices for which it is not required.

Defining Firewalls

Firewall originally referred to a fireproof wall, usually made of stone or metal that prevented flames from spreading to connected structures.

All firewalls share some common properties:

- Are resistant to attack
- Are the only transit point between networks because all traffic flows through the firewall
- Enforce the access control policy



A packet filter firewall. Is first form of network firewall

Benefits and Limitations of Firewalls

Firewalls also present some limitations:

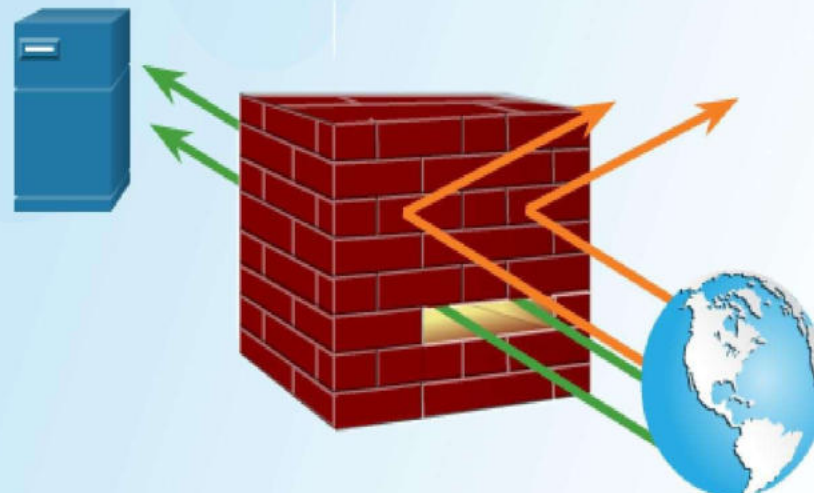
A misconfigured firewall can have serious consequences for the network

data from many applications cannot be passed over firewalls securely

Network performance can slow down.

Unauthorized traffic can be tunneled or hidden through firewall

- **Allow** traffic from any external address to the web server.
- **Allow** traffic to FTP server.
- **Allow** traffic to SMTP server.
- **Allow** traffic to internal IMAP server.
- **Deny** all inbound traffic with network addresses matching internal-registered IP addresses.
- **Deny** all inbound traffic to server from external addresses.
- **Deny** all inbound ICMP echo request traffic.
- **Deny** all inbound MS Active Directory.
- **Deny** all inbound MS SQL server ports.
- **Deny** all MS Domain Local Broadcasts.



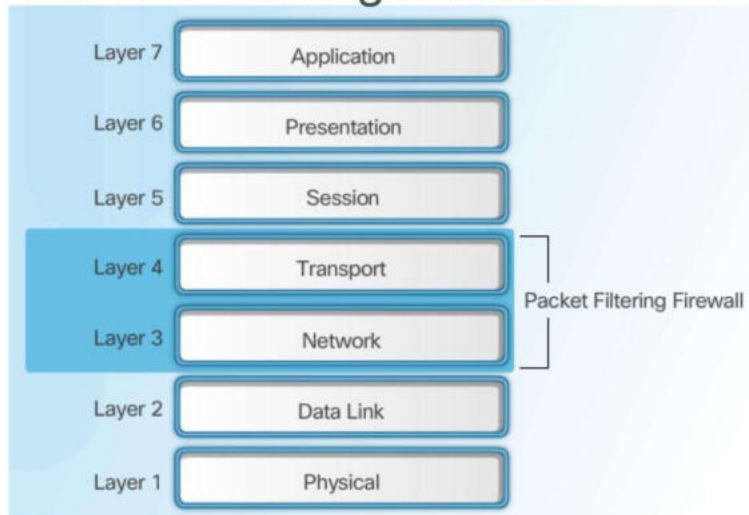
كامل مهم ماعدا مايخص العملي

Topic 4.2.2: Types of Firewalls

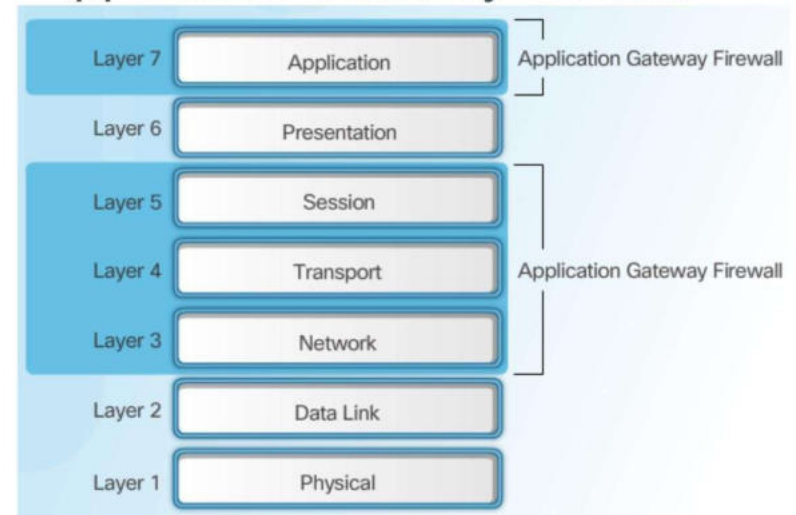


Firewall Type Descriptions

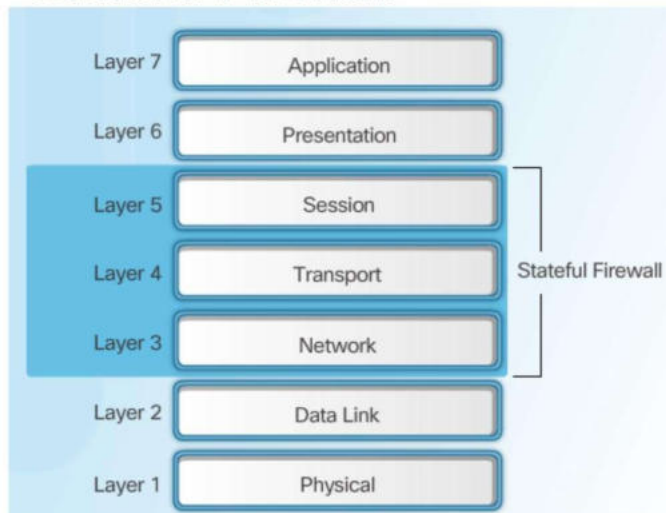
Packet Filtering Firewall



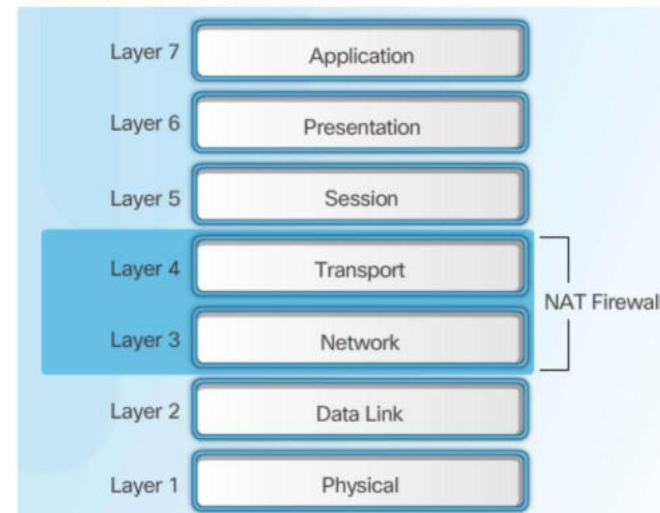
Application Gateway Firewall



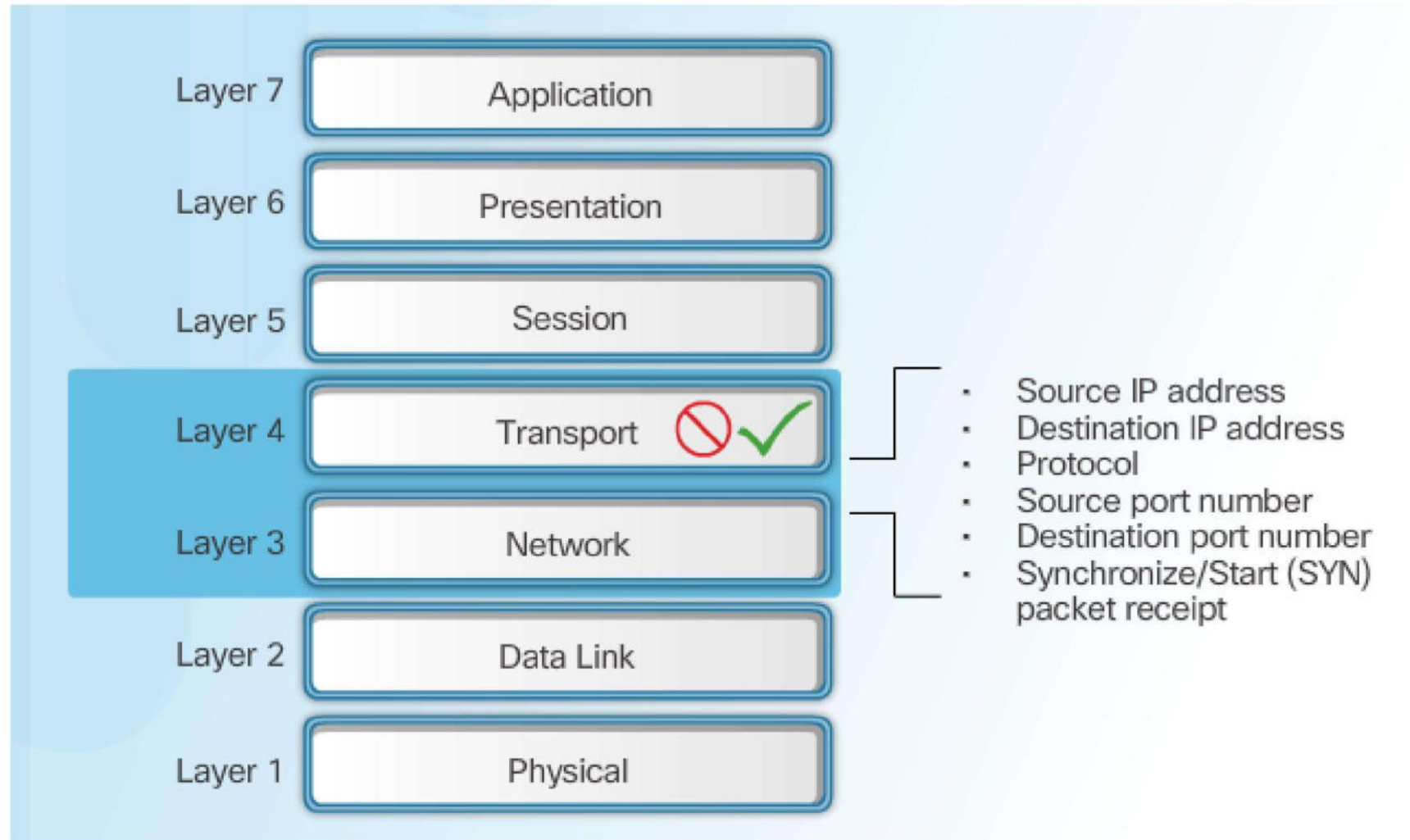
Stateful Firewall



NAT Firewall

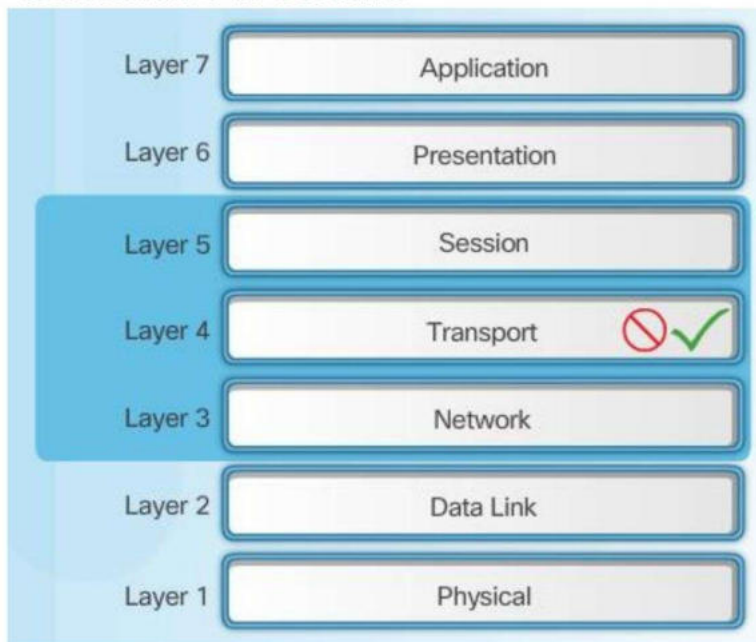


Packet Filtering (stateless) Firewall Benefits & Limitations

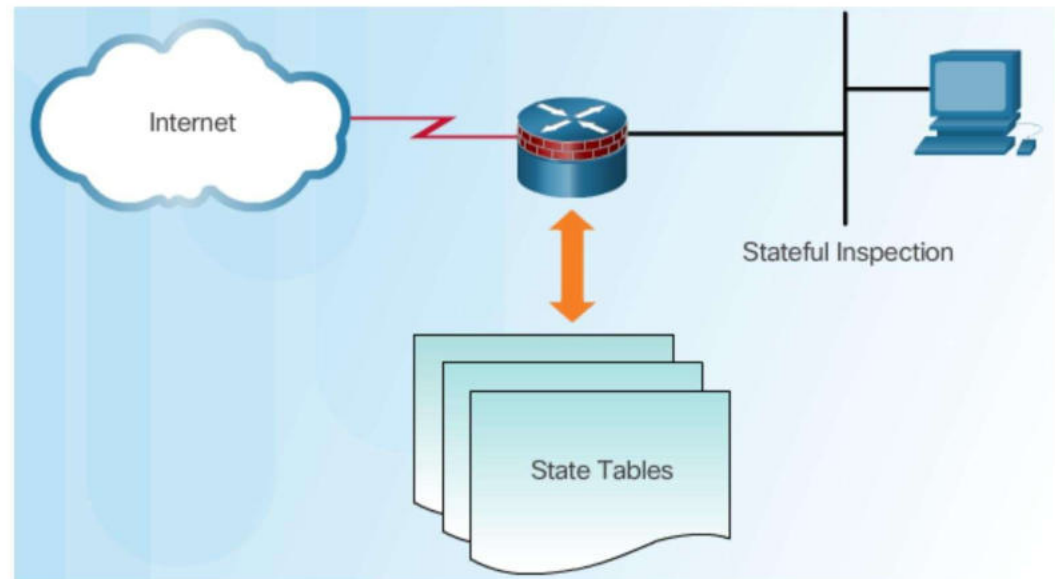


Stateful Firewalls

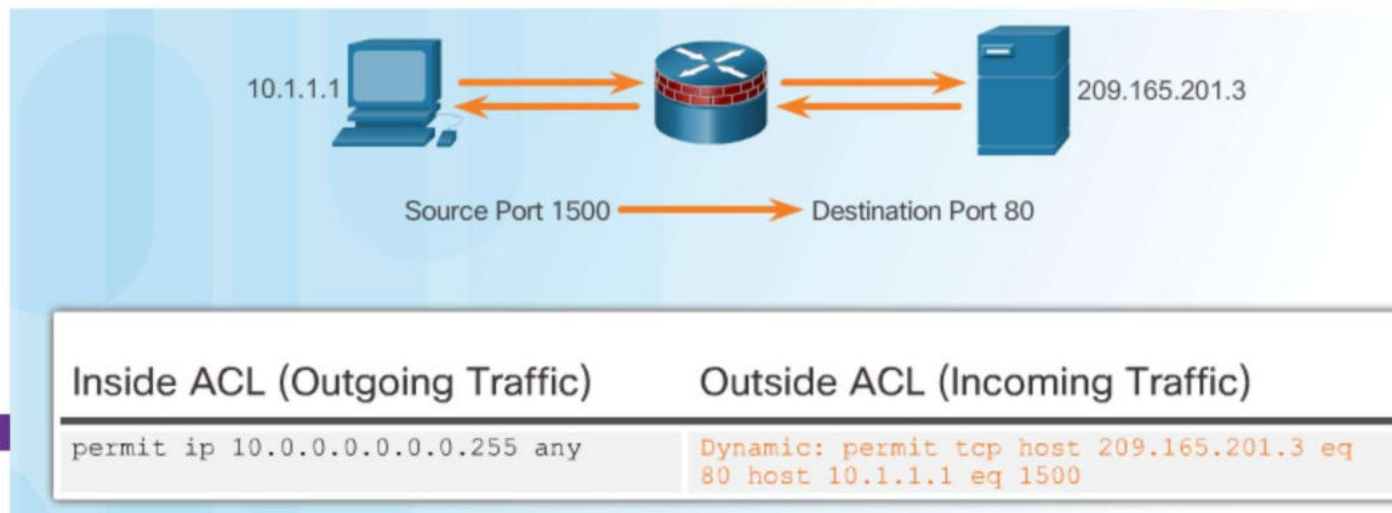
Stateful Firewalls



State Tables



Stateful Firewall Operation



Stateful Firewall Benefits and Limitations

Benefits

Limitations

Primary means of defense

No Application Layer inspection

Strong packet filtering

Cannot filter stateless protocols

Improved performance over packet filters

Difficult to defend against dynamic port negotiation

Defends against spoofing and DoS attacks

No authentication support

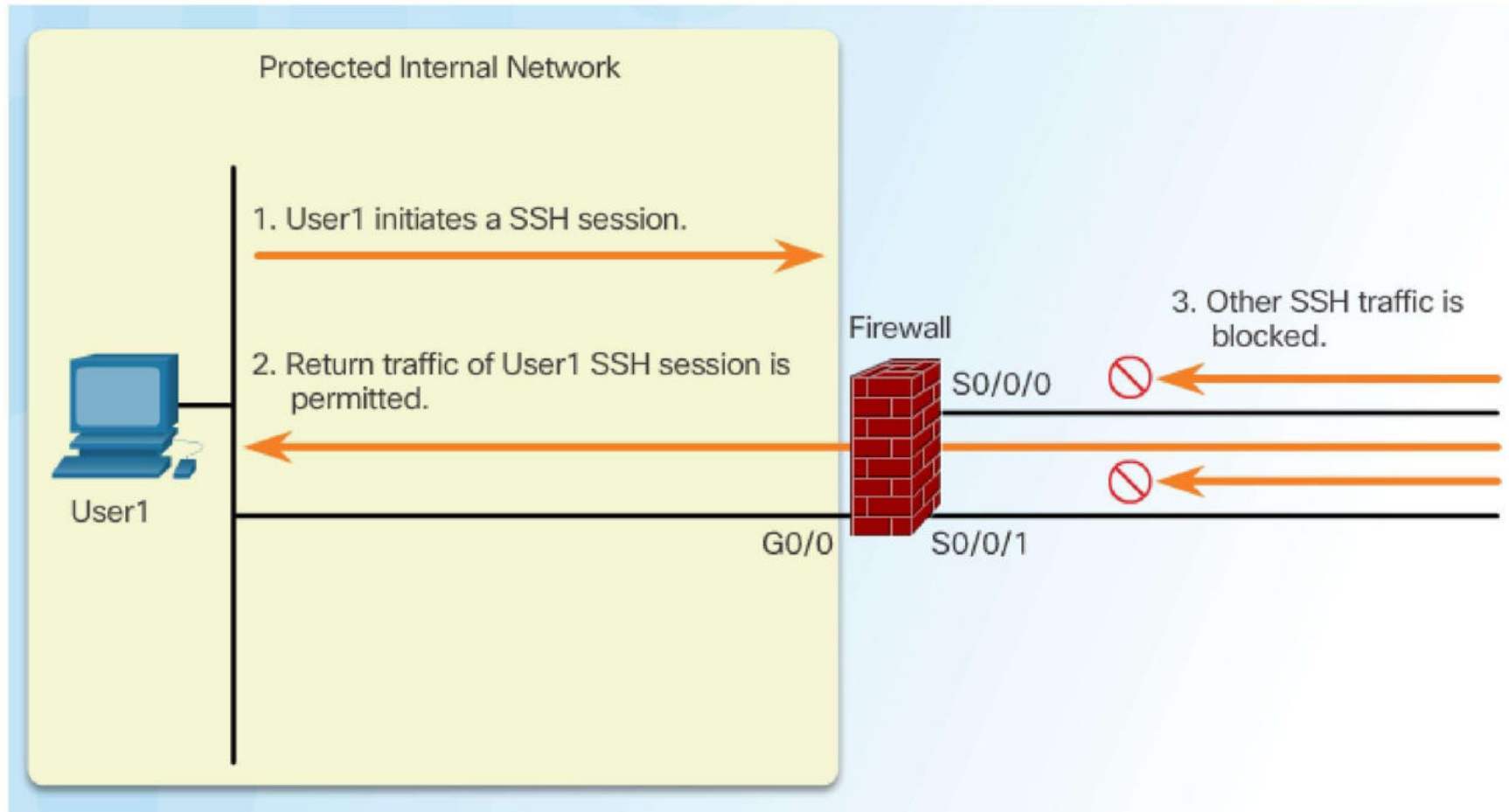
Richer data log

Next Generation Firewalls

- Granular identification, visibility, and control of behaviors within applications
- Restricting web and web application use based on the reputation of the site
- Proactive protection against Internet threats
- Enforcement of policies based on the user, device, role, application type, and threat profile
- Performance of NAT, VPN, and SPI
- Use of an IPS

Cisco ASA with FirePOWER services is also called the Cisco ASA Next-Generation Firewall because it is an adaptive, threat-focused firewall.

Introducing Classic Firewall

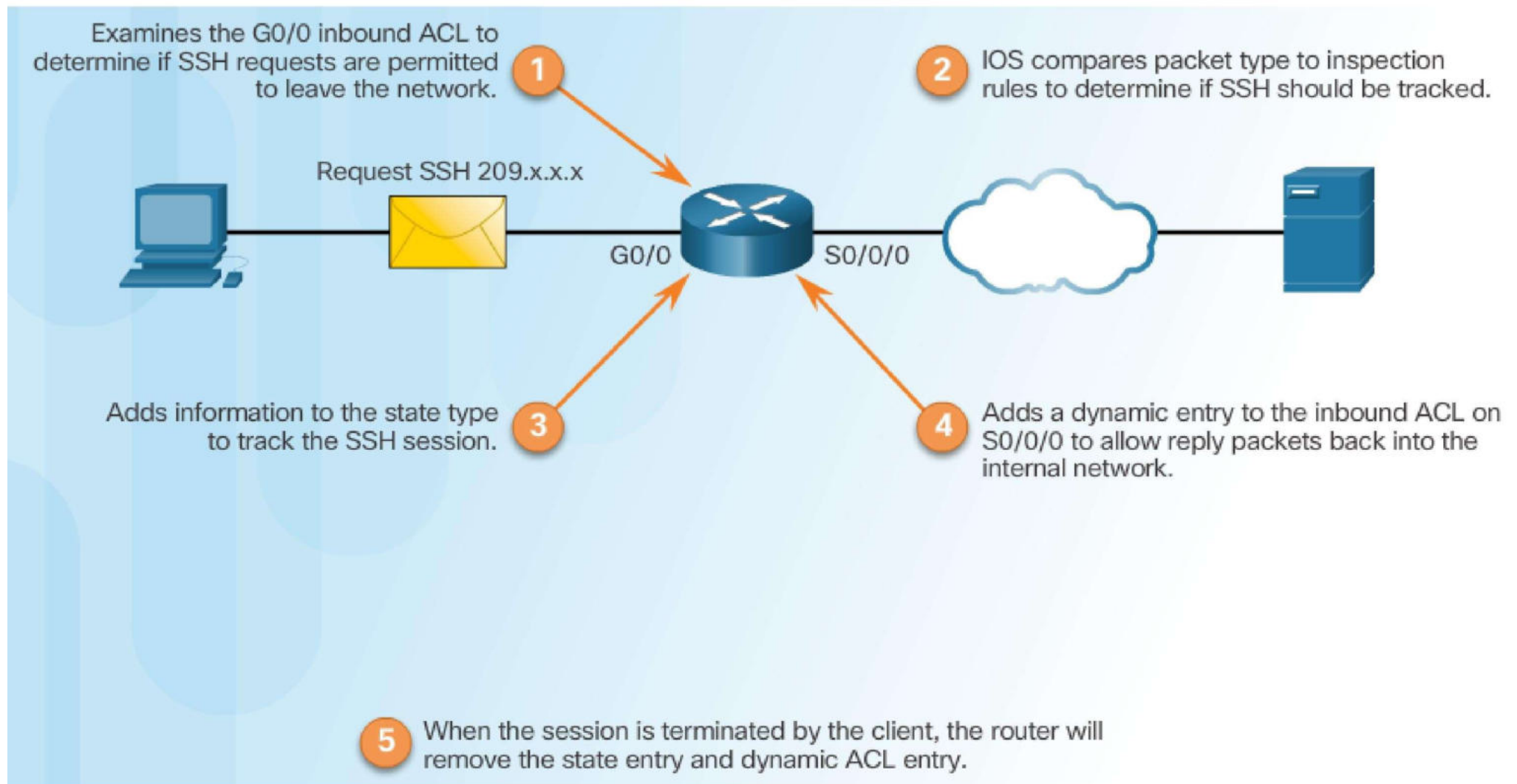


Cisco IOS Classic Firewall, formerly known as **context-based access control (CBAC)**, It is a stateful firewall feature added to the Cisco IOS prior to version 12.0.

Classic Firewall provides four main functions:

traffic filtering ,traffic inspection, intrusion detection, and generation of audits and alerts.

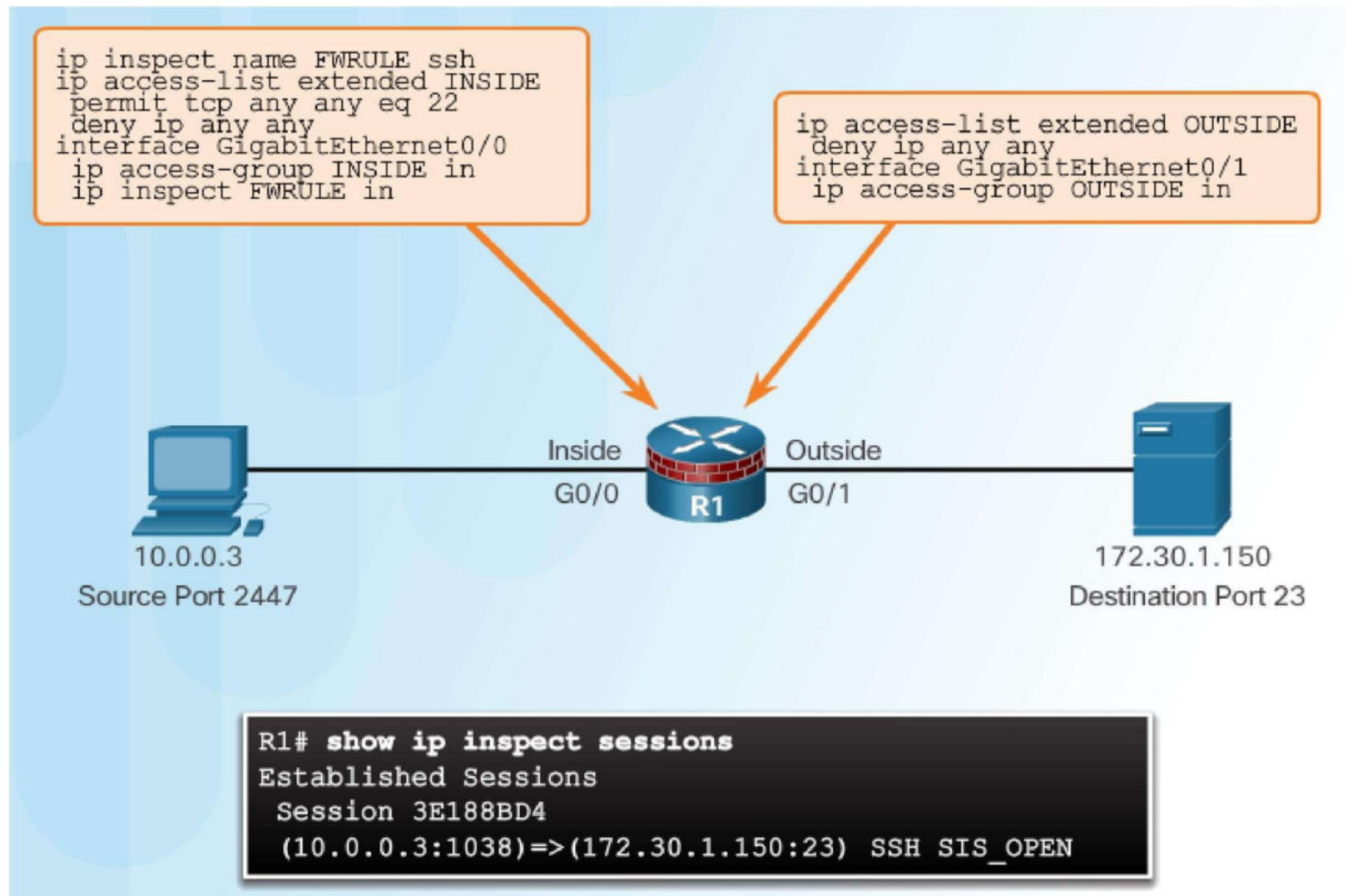
Classic Firewall Operation



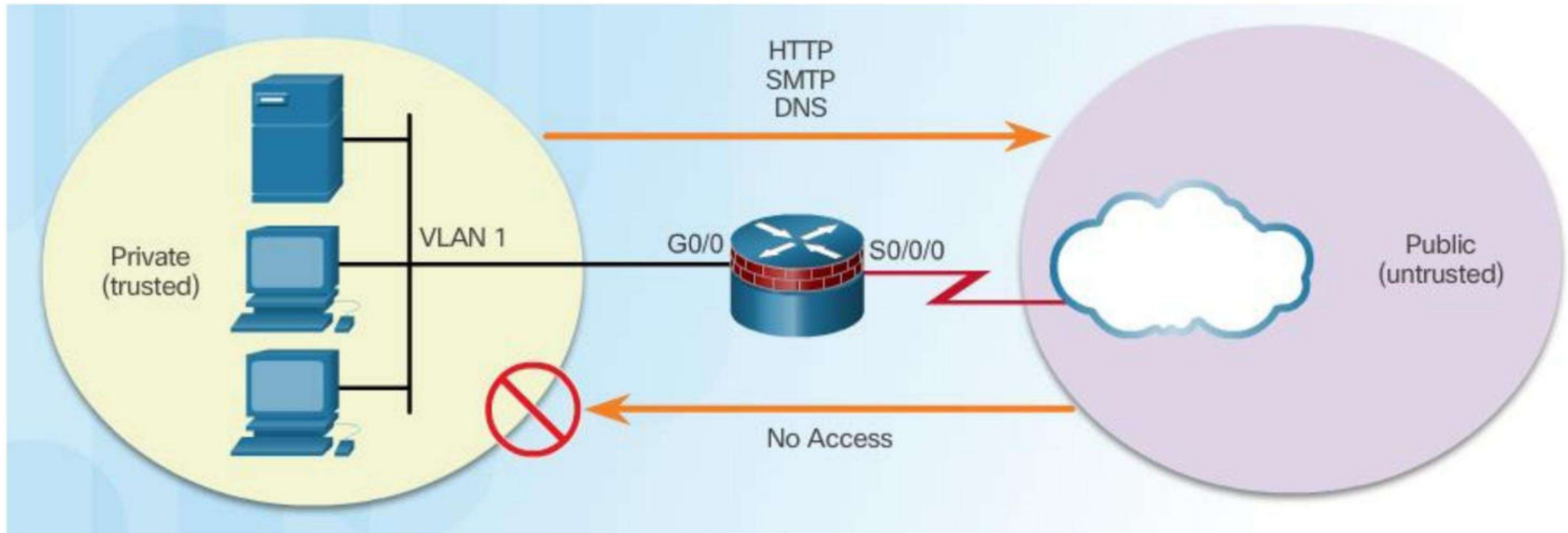
Classic Firewall Configuration

Inspection Rules

1. Choose the internal and external interfaces.
2. Configure ACLs for each interface.
3. Define inspection rules.
4. Apply an inspection rule to an interface.



Inside and Outside Networks

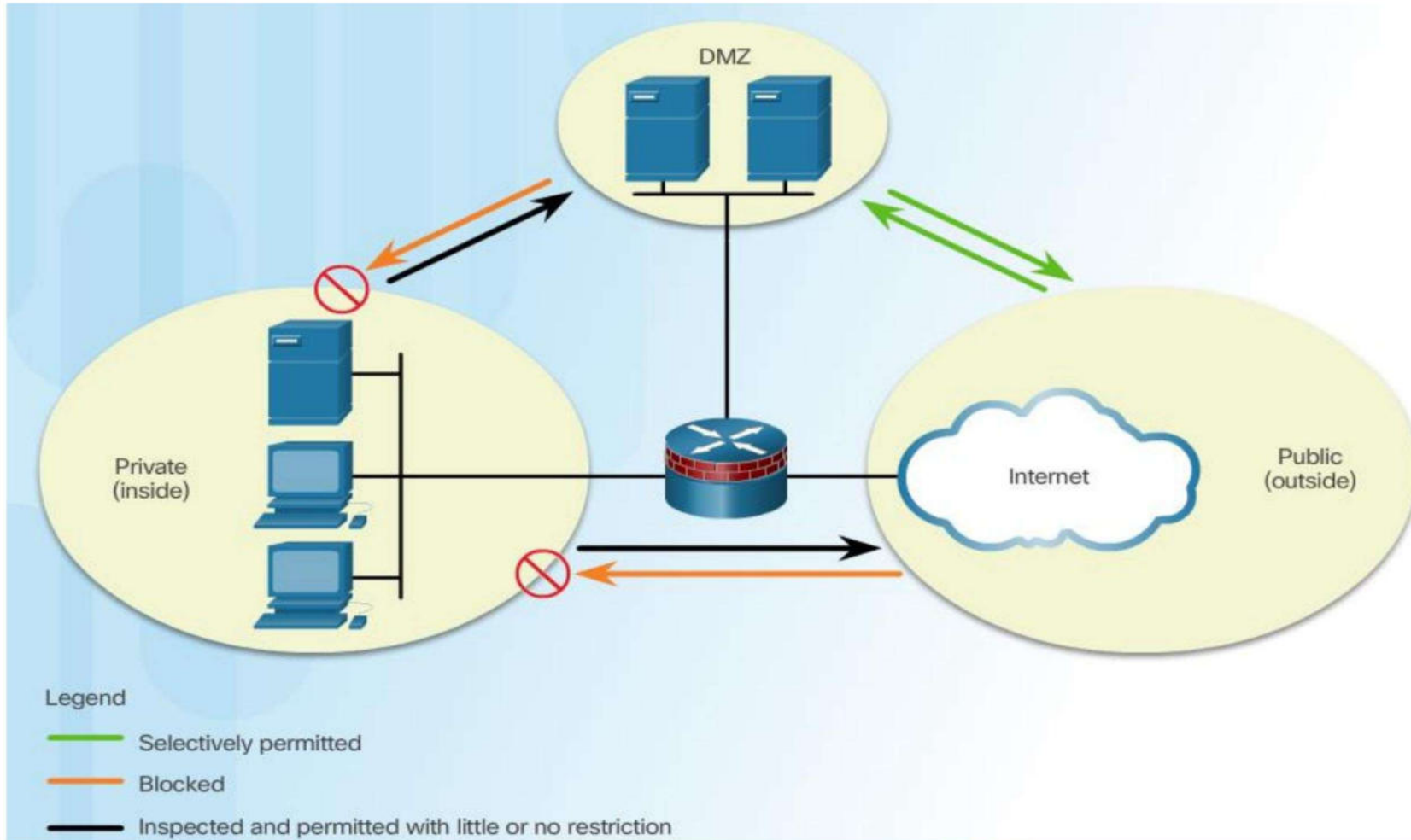


Traffic originating from the public network and traveling to the private network is generally blocked.

Traffic originating from the private network is permitted and inspected as it travels toward the public network.

Inspected traffic returning from the public network and associated with traffic that originated from the private network is permitted.

Demilitarized Zones



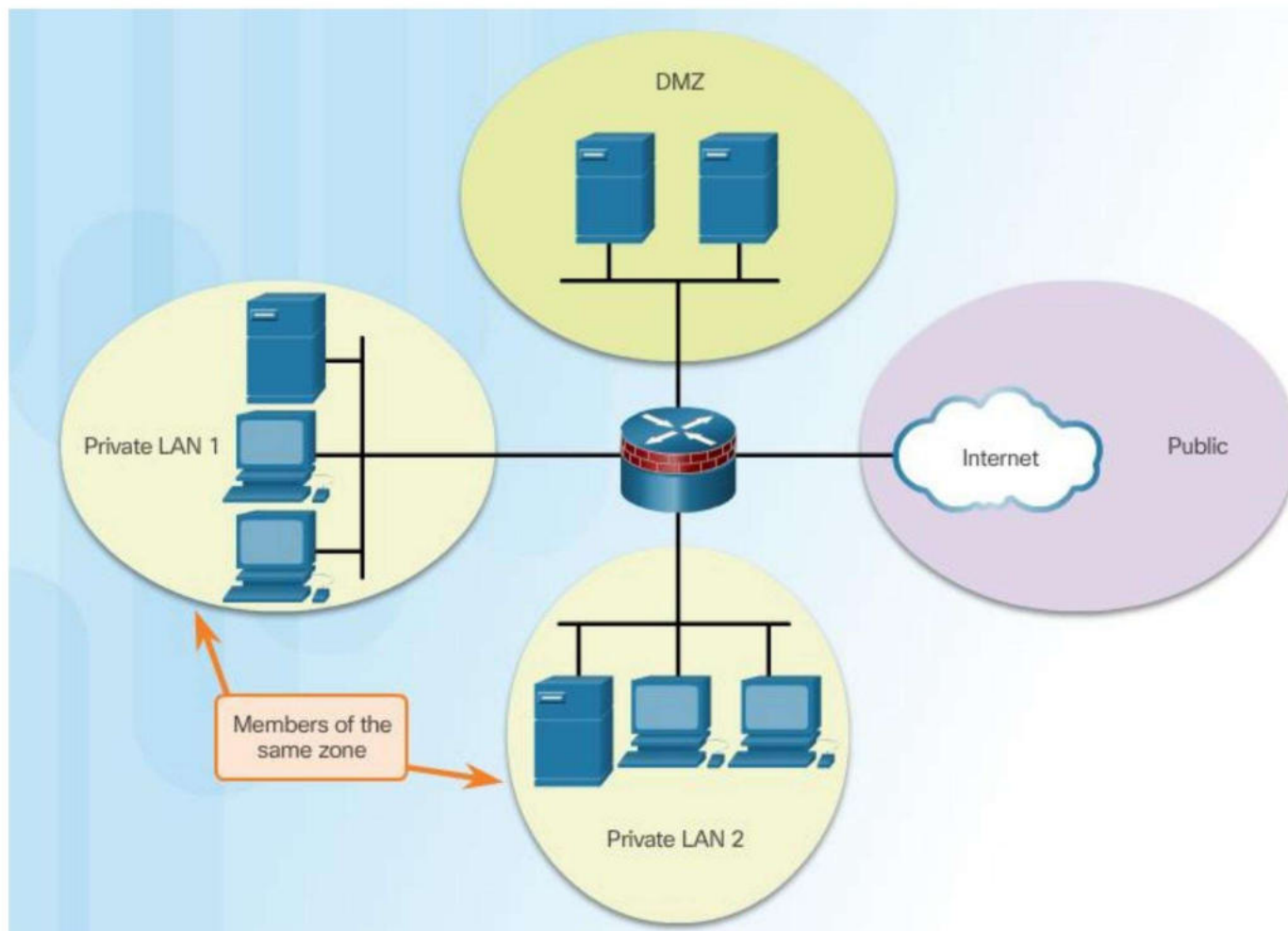
Traffic originating from the DMZ network and traveling to the private network is usually blocked.
Traffic originating from the DMZ network and traveling to the public network is selectively permitted based on service requirements.
Traffic originating from the public network and traveling toward the DMZ is selectively permitted and inspected

Zone-Based Policy Firewalls

A zone is a group of one or more interfaces that have similar functions or features.

All zone-to-zone traffic is blocked. In order to permit traffic between zones, a policy allowing or inspecting traffic must be configured.

The self zone is the router itself and includes all the router interface IP addresses. It means that traffic flowing to and from the IP addresses of the router's interfaces is not initially controlled by **zone** policies.



كامل مهم ماعدا مايخص العملي

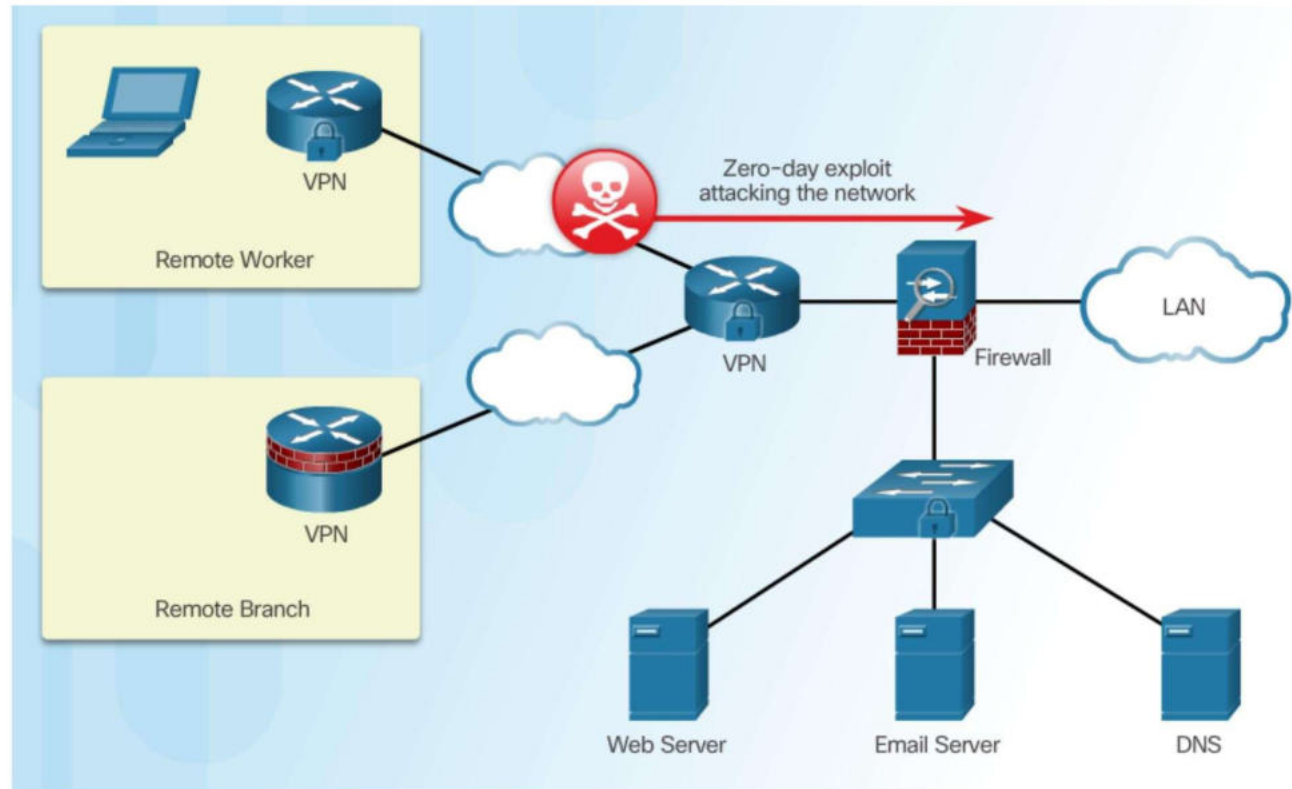
Topic 5.1.1: IDS and IPS Characteristics



Zero-Day Attacks

Firewalls can only do so much and cannot protect against malware and zero-day attacks.

Zero day attack is refer to a hole in software that is unknown to the vendor which exploited by hackers before the vendor becomes aware and hurries to fix it



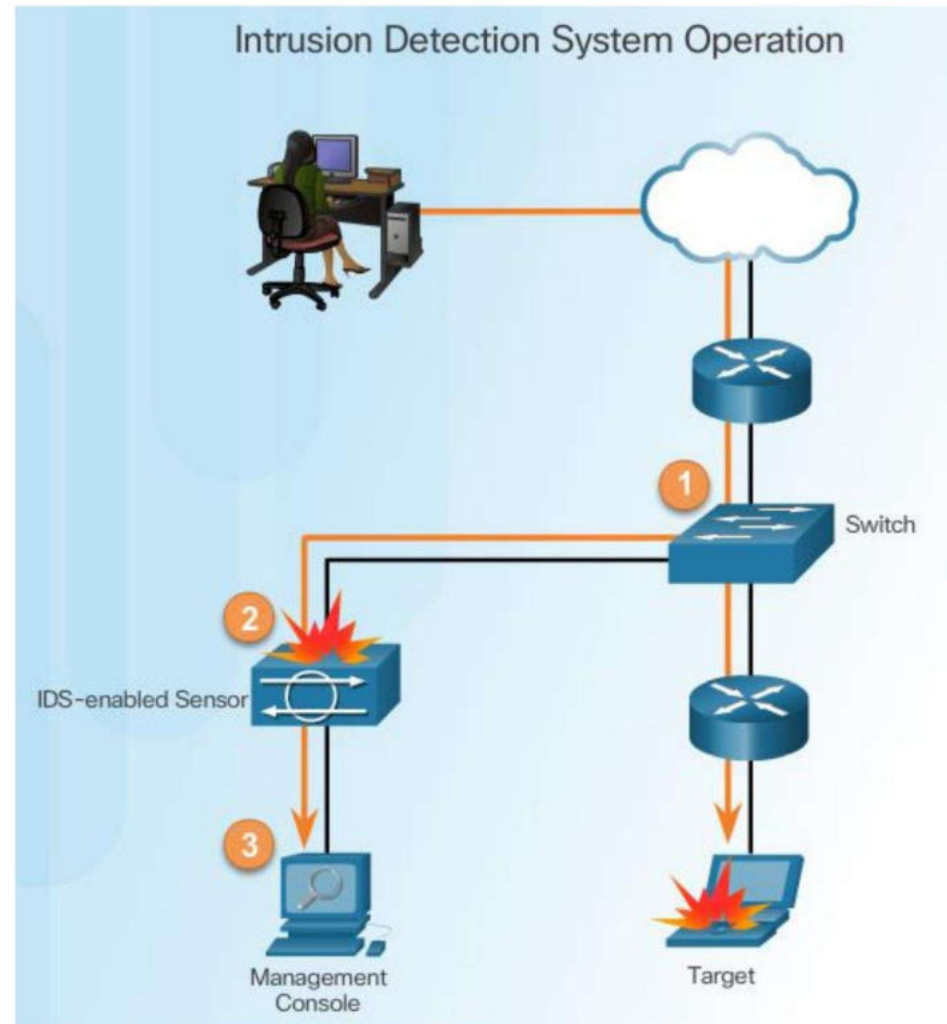
Monitor for Attacks

Monitor the network and analyze the log files is one approach to protect the network from worms and viruses but it is a time-consuming task !

IDS were implemented to passively monitor the traffic on a network.

Advantages of an IDS:

- Works passively (working offline)(promiscuous mode.)
- Requires traffic to be mirrored in order to reach it
- Network traffic does not pass through the IDS unless it is mirrored
- Does not negatively affect the packet flow of the forwarded traffic.
- Copies the traffic stream and analyzes the copied traffic rather than the actual forwarded packets.



Detect and Stop Attacks

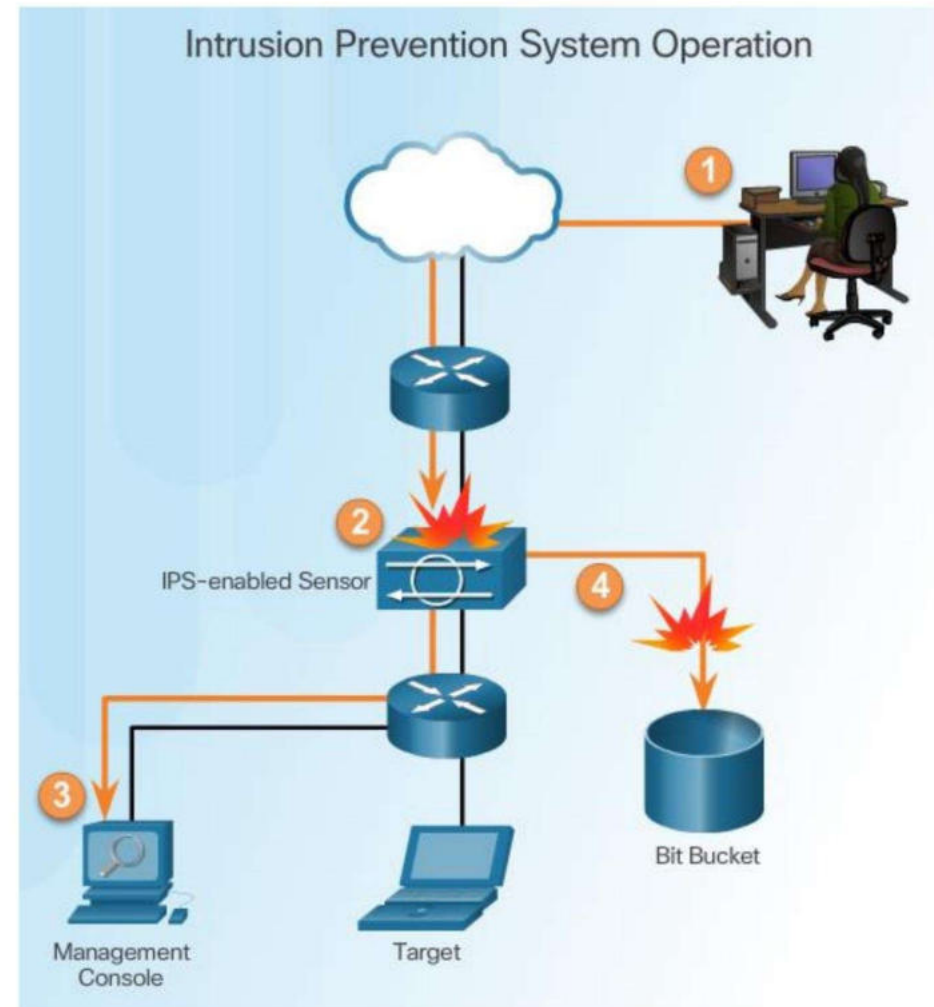
Unlike IDS , IPS device is implemented in inline mode.

This means that all ingress and egress traffic must flow through it for processing.

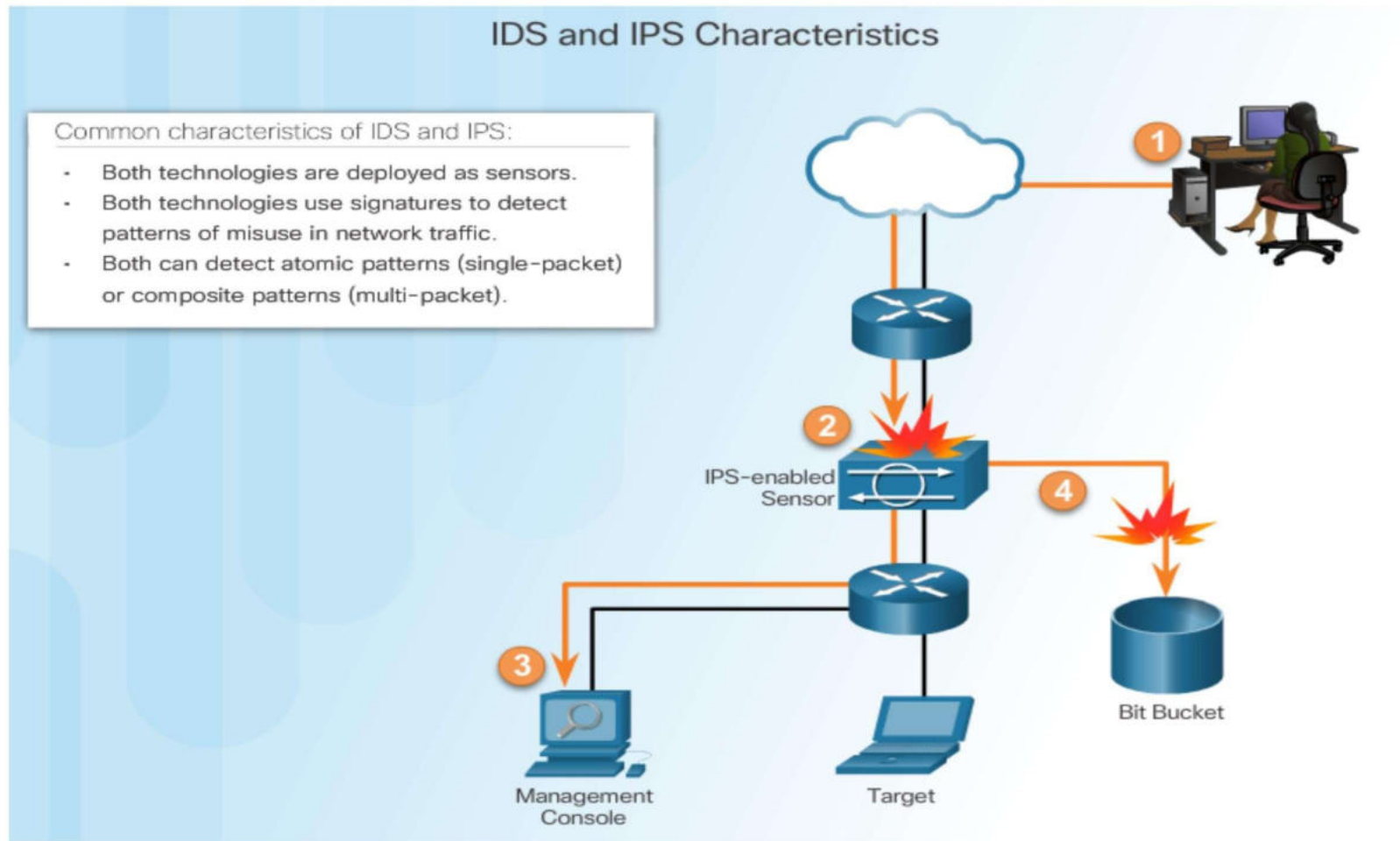
Cisco IPS platforms use a blend of detection technologies, including **signature-based**, **profile-based**, and **protocol analysis-based intrusion detection**.

IPS:

- Implemented in an inline mode
- Monitors Layer 3 and Layer 4 traffic
- Can stop single packet attacks from reaching target
- Responds immediately, not allowing any malicious traffic to pass



Similarities Between IDS and IPS



An IDS or IPS sensor can be any of the following devices:

Router configured with Cisco IOS IPS software.

Appliance specifically designed to provide dedicated IDS or IPS services.

Network module installed in an adaptive security appliance, switch, or router

Advantages and Disadvantages of IDS and IPS

Advantages IDS:

- No impact on network
- No network impact if there is a sensor failure
- No network impact if there is a sensor overload

Disadvantages IDS:

- Response action cannot stop trigger
- Correct tuning required for response actions
- More vulnerable to network security evasion techniques

Advantages IPS:

- Stops trigger packets
- Can use stream normalization techniques (It is a technique used to reconstruct the data stream when the attack occurs over multiple data segments such as fragmentation reassembly to check the validity of the transmission)

Disadvantages IPS:

- Sensor issues might affect network traffic
- Sensor overloading impacts the network
- Some impact on network

An IPS is a control tool, however an IDS is a visibility tool.

كامل مهم ماعدا مايخص العملي

Topic 5.1.2: Network-Based IPS Implementations



Host-Based and Network-Based IPS

There are two primary kinds of IPSs available: Host-based and network-based.

Host-based IPS (HIPS) is software installed on a single host to monitor and analyze suspicious activity.

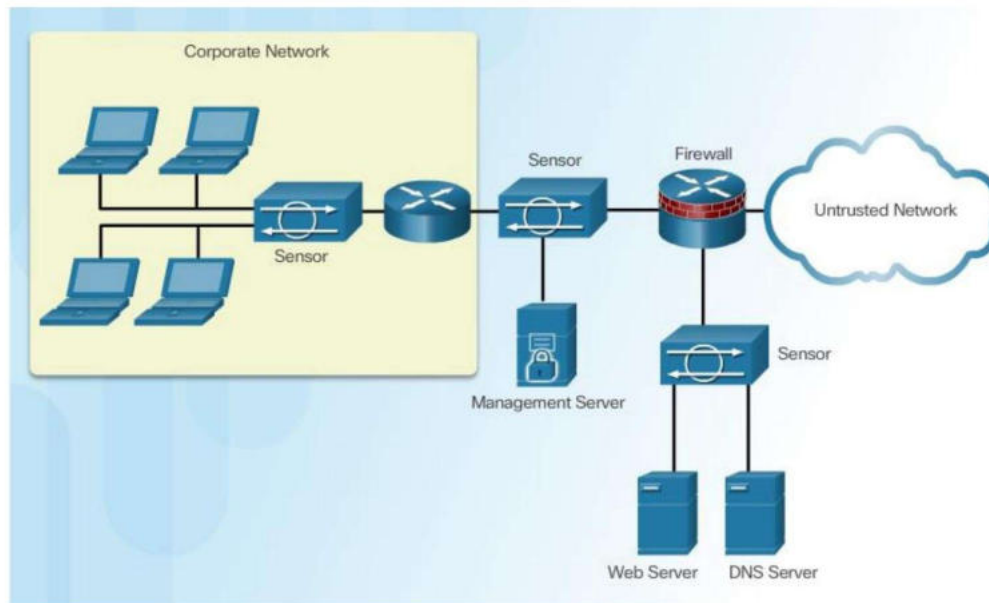
It can monitor abnormal activity and prevent the host from executing commands that do not match typical behavior.

HIPS is that it operates only at a local level. It does not have a complete view of the network.

A network-based IPS can be implemented using a dedicated or non-dedicated IPS device.(added to an ISR router, ASA firewall or Catalyst 6500 switch)

Advantages		Disadvantages
Host-Based IPS	• Provides protection specific to a host operating system • Provides operating system and application level protection • Protects the host after the message is decrypted	• Operating system dependent • Must be installed on all hosts
Network-Based IPS	• Cost effective • Operating system independent	• Cannot examine encrypted traffic • Must stop malicious traffic prior to arriving at host

Network-Based IPS Sensors



A network-based IPS can be implemented using a dedicated or non-dedicated IPS device. Network-based IPS implementations are a critical component of intrusion prevention.

There are host-based IDS/IPS solutions, but these must be integrated with a network-based IPS implementation to ensure a robust security architecture.

Cisco's Modular and Appliance-Based IPS Solutions



Cisco IPS AIM and Network Module Enhanced (IPS NME)



Cisco ASA AIP-SSM



Cisco IPS 4300 Series Sensors



Cisco Catalyst 6500 Series IDSM-2

Choose an IPS Solution

The choice of a sensor varies depending on the requirements of the organization.

Factors affecting the IPS sensor selection and deployment:

- Amount of network traffic
- Network topology
- Security budget
- Available security staff to manage IPS

IPS Advantages and Disadvantages

Advantages

Disadvantages

Network IPS

- Is cost-effective
- Not visible on the network
- Operating system independent
- Lower level network events seen

- Cannot examine encrypted traffic
- Cannot determine whether an attack was successful

Introducing VPNs

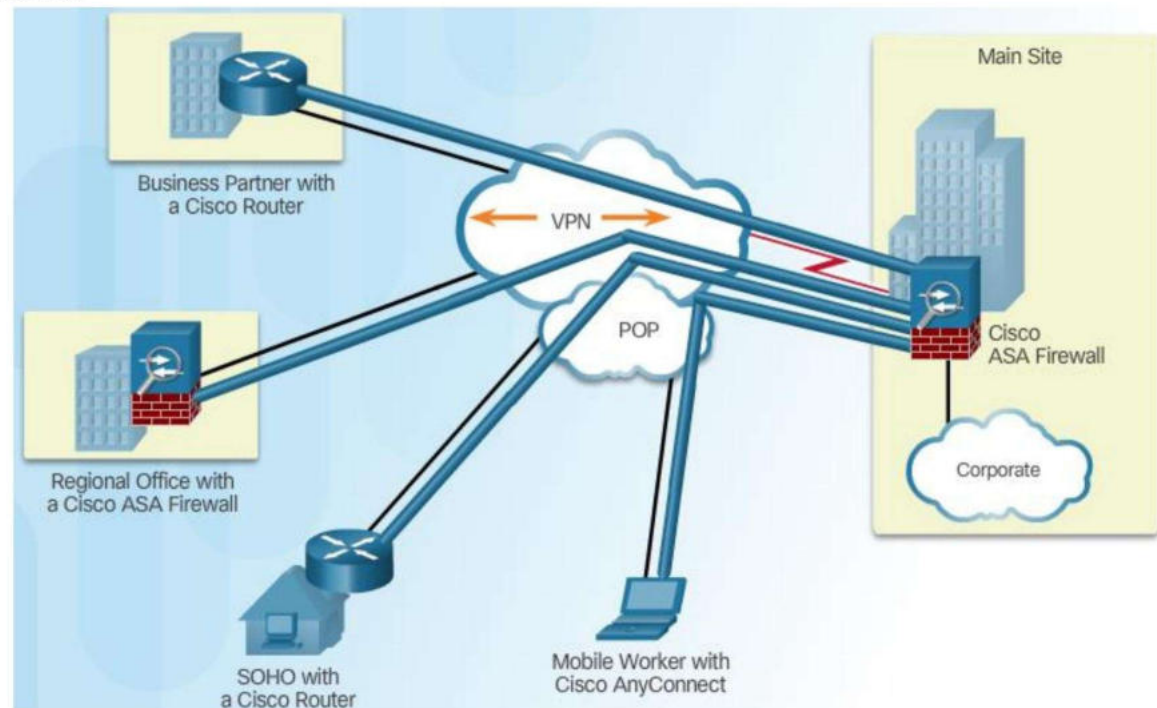
A VPN is a private network that is created via tunneling over a public network, usually the Internet.

A VPN is *virtual* in that it carries information within a private network, but that information is actually transported over a public network.

A VPN is *private* in that the traffic is encrypted to keep the data confidential while it is transported across the public network.

VPN Benefits:

- Cost Savings
- Security
- Scalability
- Compatibility



Layer 3 IPsec VPNs

IPsec services allow for authentication, integrity, access control, and confidentiality. With IPsec, the information exchanged between remote sites can be encrypted and verified.

Example of Layer 3
VPNs:

GRE,
Multiprotocol Label
Switching (MPLS),
IPsec

